

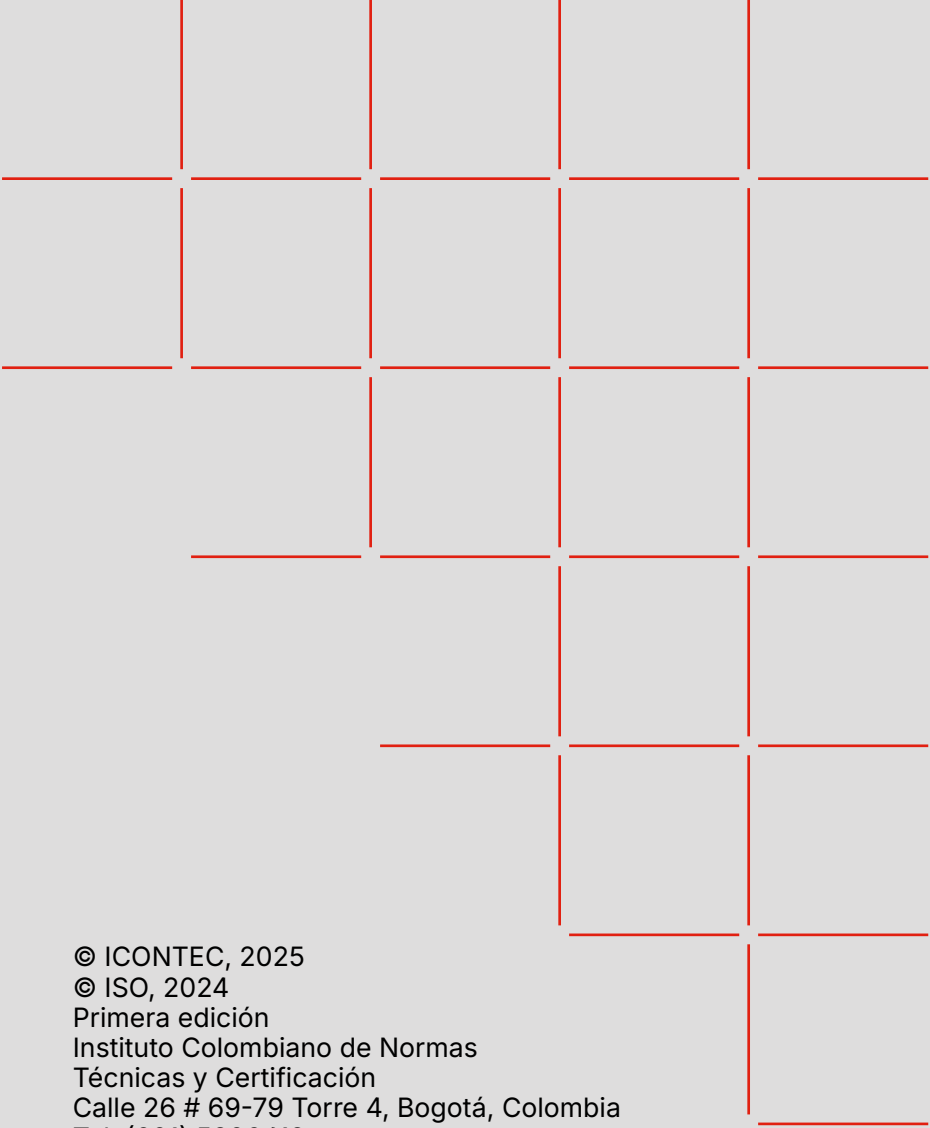


NTC ISO/IEC 27001:2022 Sistemas de gestión de seguridad de la información.

Una guía práctica para las pymes



Subcomité Técnico
ISO/IEC JTC 1/SC 27



© ICONTEC, 2025
© ISO, 2024
Primera edición
Instituto Colombiano de Normas
Técnicas y Certificación
Calle 26 # 69-79 Torre 4, Bogotá, Colombia
Tel: (601) 5806419

ISBN: 978-628-7823-05-1

Todos los derechos reservados. No se permite la reproducción de este libro, total o parcial, ni su uso para sistemas de recuperación o procesamiento de información, en ninguna forma, sea mecánica o magnética, sin el permiso explícito de su autor o del editor.

Prólogo

La ciberdelincuencia va en aumento, y se torna más grave y sofisticada a medida que los piratas informáticos desarrollan técnicas cada vez más avanzadas. En este panorama tan cambiante, puede parecer difícil o incluso imposible hacer un seguimiento de los riesgos cibernéticos. Desde la Organización Internacional de Normalización (ISO, por su sigla en inglés), se ofrece preparación mediante apoyos y soluciones para ayudar a las pequeñas y medianas empresas (pymes) a navegar de manera segura a través de este proceso.

Este manual se centra en orientar a las pymes en el desarrollo e implementación de un sistema de gestión de seguridad de la información (SGSI), de acuerdo con la NTC ISO/IEC 27001:2022, con el fin de ayudarle a proteger su empresa de los riesgos cibernéticos.

Las pymes representan la gran mayoría de los negocios en todo el mundo y, a menudo, tienen necesidades específicas. Las normas internacionales les ayudan a competir en igualdad de condiciones con empresas más grandes, acceder a los mercados globales, reducir costos y fomentar la confianza de los clientes en la seguridad y confiabilidad de sus productos. Entendemos los desafíos únicos a los que se enfrenta como pyme, ya sea por falta de dinero, de recursos o de una comprensión completa de los problemas, y que pueden hacer que su seguridad se vea comprometida.

La norma ISO/IEC 27001 es la norma líder a nivel mundial para los SGSI, y les proporciona a las organizaciones orientaciones sobre el establecimiento, la implementación, el mantenimiento y la mejora continua de un SGSI. Define los requisitos para un SGSI y les ayuda a las organizaciones a proteger sus activos de información mediante la identificación y gestión de los riesgos, una actividad vital en el mundo digital actual. Los requisitos que describe la NTC ISO/IEC 27001:2022

son genéricos, y están diseñados para ser escalables y flexibles; por lo tanto, se aplican a todo tipo de organizaciones, independientemente de su tamaño o de la naturaleza de sus actividades comerciales o de su sector.

La implementación de la NTC ISO/IEC 27001:2022 significa que su organización o empresa ha puesto en marcha un sistema para gestionar los riesgos relacionados con la seguridad de los datos que posee o maneja la empresa, y que este sistema respeta todas las buenas prácticas y principios consagrados en la norma.

Mediante el uso de la NTC ISO/IEC 27001:2022, le demuestra a las partes interesadas y a los clientes que está comprometido con gestionar la información de forma segura y protegida. Es una forma única de promocionar su organización, celebrar sus logros y demostrar que se puede confiar en usted. Además, el enfoque holístico de la NTC ISO/IEC 27001:2022 implica que toda la organización está cubierta, no solo las tecnologías de la información (TI). Tanto las personas, como la tecnología y los procesos se benefician.

Este manual fue desarrollado por expertos de la comunidad técnica conjunta de seguridad de la información, ciberseguridad y protección de la privacidad de la ISO y la Comisión Electrotécnica Internacional (IEC, por su sigla en inglés). Sinceramente espero que este manual apoye los esfuerzos de su empresa en el desarrollo de un SGSI que actúe como una herramienta para la gestión de riesgos, la resiliencia cibernética y la excelencia operativa. De ese modo, esperamos que su organización implemente esta norma y emerja como líder en su industria.



Sergio Mujica
Secretario General de la ISO

Contenido

Prólogo	3
Acerca de este manual	6
Sistemas de gestión de seguridad de la información	8
Uso del manual	10
Orientaciones sobre qué significa la NTC ISO/IEC 27001 para las pymes	13
Terminología	14
El prólogo de la NTC-ISO/IEC 27001	16
Introducción	17
1. Objeto y campo de aplicación	18
2. Referencias normativas	19
3. Términos y definiciones	20
4. Contexto de la organización	20
5. Liderazgo	29
6. Planificación	36
7. Apoyo	64
8. Operación	77
9. Evaluación del desempeño	81
10. Mejora	87
Anexo A. Preguntas frecuentes	92
Anexo B. Certificación	98
Anexo C. Sitios web y normas internacionales	108

Acerca de este manual

El objetivo de este manual es orientar a las pequeñas y medianas empresas (pymes) en el desarrollo y la implementación de un sistema de gestión de seguridad de la información (SGSI), basado en la NTC ISO/IEC 27001:2022, Seguridad de la información, ciberseguridad y protección de la privacidad. Sistemas de gestión de seguridad de la información. Requisitos.

En el resto de este manual se hará referencia a esta norma como NTC-ISO/IEC 27001 para mayor brevedad. Los requisitos que describe la NTC-ISO/IEC 27001 son genéricos y están diseñados para ser escalables y flexibles, por lo tanto, se aplican a todo tipo de organizaciones, independientemente de su tamaño o de la naturaleza de sus actividades comerciales o de su sector. Este manual se centra en orientar a las pymes.

En sentido estricto, en la práctica una pyme es una organización. Sin embargo, las pymes normalmente no se consideran a sí mismas como organizaciones, ya que por lo general el término se refiere a una entidad que es mayor en tamaño y complejidad. Por lo tanto, en este manual se utiliza con frecuencia el término empresa, que es coherente con el concepto reconocido de las pymes.

En este contexto, el término empresa incluye a todas las organizaciones que utilizan, procesan, intercambian y almacenan información para sus propias necesidades internas y en nombre de otros, como sus clientes o proveedores. Algunos ejemplos de empresas son los pequeños negocios familiares, los fabricantes, los distribuidores, las escuelas, los puntos de venta al por menor, los bufetes de abogados, las fundaciones benéficas, las residencias para personas mayores y los centros médicos comunitarios.

Este manual consta de una serie de secciones que los lectores pueden aplicar y consultar por separado, según sea necesario. Así pues, el manual es un documento de apoyo para las pymes que aplican la NTC ISO/IEC 27001. Este manual no agrega requisitos a los de la norma, ni modifica los existentes.

En comparación con entidades más grandes, las pymes se enfrentan a retos particulares a la hora de desarrollar un SGSI, como la disponibilidad de recursos. Con un número limitado de empleados, una pyme podría no tener la capacidad para dedicar un equipo a la gestión de un SGSI. Por lo tanto, se esperaría que los individuos dentro de una pyme incluyeran la seguridad de la información de forma adicional a sus funciones

principales. Otro desafío es el costo que implica desarrollar y mantener un SGSI. Hay muchos factores que hacen que los costes puedan ser inferiores a los de una organización más grande. Las comunicaciones, por ejemplo, a menudo pueden ser simples y más directas; la toma de decisiones suele ser más simple, e involucra solo a unas pocas personas; la gestión puede ser más directa, gracias a estructuras más simples, y la gestión de riesgos generalmente es menos complicada.

Desde el punto de vista de una pyme, el tiempo y el dinero destinados a un SGSI se deberían considerar como una inversión que proporciona oportunidades de negocio, a la vez que muestra un retorno de la inversión, y que incluye la protección de la información de la empresa y les proporciona seguridad y confianza a los clientes. Dado que la NTC ISO/IEC 27001 es una norma flexible y escalable, estos desafíos no deberían ser una barrera para que las pequeñas empresas implementen la norma.

Sistemas de gestión de seguridad de la información

¿Qué es un SGSI?

Un sistema de gestión se define como un conjunto de elementos interrelacionados o interactivos de una organización que establecen políticas y objetivos, así como procesos para alcanzar esos objetivos. En términos simples, un sistema de gestión es la forma en la que una empresa dirige y controla las actividades comerciales están relacionadas (sea directa o indirectamente) con el cumplimiento de sus objetivos y resultados previstos.

Para un SGSI, los objetivos son la preservación de la confidencialidad, la integridad y la disponibilidad de la información bajo su control. Las actividades comerciales de su empresa deberían estar dirigidas, controladas y gestionadas de manera que estos objetivos de seguridad de la información se cumplan. Para ello, es necesario considerar los requisitos de las partes interesadas pertinentes en la planificación, el funcionamiento y la gestión de su SGSI, con el fin de cumplir estos objetivos. Por ejemplo, una parte interesada podría ser uno de sus clientes y sus requisitos, asociados con sus productos y servicios.

La NTC ISO/IEC 27001 especifica los requisitos para establecer, implementar, mantener y mejorar continuamente un SGSI.

La NTC ISO/IEC 27001 no se debería confundir con otras normas de seguridad; por ejemplo, aquellas que especifican requisitos explícitos y técnicas para proteger los productos, las redes y los servicios de TI. La NTC ISO/IEC 27001 especifica los requisitos para las buenas prácticas de gestión con el fin de alcanzar la gestión de la seguridad de la información, pero sin hacer referencia a ningún tipo particular de producto, red o servicio de TI.

La implementación y el uso de un SGSI no debería resultar en reglas, papeleo y documentación excesivos, ni a una falta de flexibilidad, y no deberían ser una carga financiera. La implementación, el uso y el mantenimiento de un SGSI se deberían considerar una inversión que ofrecerá un retorno en forma de beneficios y mejoras en la seguridad de su información.

Todas las empresas ya contarán con algún tipo de sistema de gestión y este debería ser la base sobre la que se construya su sistema de gestión de la información. Por lo tanto, es probable que su empresa ya pueda cumplir con al menos algunos de los requisitos incluidos en la NTC ISO/IEC 27001, pero, simplemente, todavía no ha organizado sus actividades en un SGSI formal.

¿Por qué tener un SGSI?

Implementar un SGSI es una decisión estratégica de la empresa, para proteger su información contra amenazas y riesgos. Dichas amenazas pueden incluir, por ejemplo, el robo de información en línea o su modificación no autorizada. Los clientes también podrían querer garantías de que una empresa protege su información. Además, podría haber una ley o reglamento que exija que se protejan ciertos tipos de información, como los datos personales.

Un SGSI proporciona un enfoque sistemático para cumplir los objetivos y requisitos de seguridad de la información de una empresa, lo que debería conducir a mejoras en la seguridad de la información.

Uso del manual

Público objetivo

El público objetivo de este manual son las pymes. Esto incluye todos los tipos de pequeñas empresas, y abarca todos los tipos de actividades comerciales y diferentes estilos de gestión y propiedad que las diferencian de las organizaciones medianas y grandes.

Empezar

En un principio, las pymes deberían utilizar este manual para comprender tanto los requisitos de la NTC ISO/IEC 27001 como qué es un SGSI.

Es importante tener en cuenta que la intención de la NTC ISO/IEC 27001 no es imponer una forma totalmente nueva de gestionar una empresa. En la medida de lo posible, una empresa debería seguir utilizando sus procesos de gestión, y adaptarlos o ampliarlos, si es necesario, para implementar un SGSI eficaz. Para que una empresa siga este consejo, debería revisar cómo gestiona su negocio y cómo es su operación actual, con el fin de personalizar sus sistemas cuando sea necesario y de satisfacer los requisitos de la NTC ISO/IEC 27001. Por lo tanto, una empresa no necesita comenzar desde el principio; debería utilizar lo que ya está en marcha y adaptarlo según sea necesario.

Una pequeña empresa tendrá muchos aspectos de gestión relacionados con su negocio que son más sencillos y menos complejos que los de una organización mediana o grande. Por ejemplo, la toma de decisiones suele ser un proceso menos complicado. Por lo tanto, para una pequeña empresa, estos ejemplos pueden ser ventajosos y facilitar mucho la implementación de la NTC ISO/IEC 27001.

Por lo tanto, será necesario analizar qué requisitos de la NTC ISO/IEC 27001 aplican a su empresa y si satisface o no estos requisitos.

Si está utilizando la edición del 2013 de la NTC ISO/IEC 27001, será necesario que revise sus prácticas actuales, y que luego las actualice para satisfacer los requisitos de la edición del 2022.

Obtener ayuda y apoyo

Hay muchas fuentes que ofrecen información y consejo (véase el Anexo C):

- asociaciones industriales o profesionales, especialmente las que pueden ofrecer orientación a las pymes;
- departamentos gubernamentales que se especializan en brindarles apoyo y consejo a las pymes;
- organismos nacionales de normalización;
- Sitios web de internet que contienen información sobre el SGSI, por ejemplo, el de la ISO ([iso.org/standard/27001](https://www.iso.org/standard/27001) y [committee.iso.org/home/jtc1sc27](https://www.iso.org/committee.iso.org/home/jtc1sc27));
- proveedores de cursos de formación;
- organismos de certificación;
- consultores.

Estas fuentes pueden ayudarle a comprender qué necesita hacer su empresa para implementar un SGSI. A continuación, es necesario que su empresa decida si seguir adelante con un SGSI. Si su empresa decide seguir adelante, entonces necesita determinar qué tanto del trabajo puede hacer y cuánta ayuda de fuentes externas necesita.

Será necesario que su empresa considere qué recursos (personas y tiempo) tiene disponibles para hacer el trabajo y esto determinará cuánta ayuda adicional podría necesitar. Una vez más, las fuentes enumeradas anteriormente pueden tener la capacidad de ofrecer ayuda adicional, pero será necesario que su empresa tenga en cuenta los costos asociados.

Antes de utilizar fuentes externas de ayuda, es necesario tener en cuenta y en consideración lo siguiente:

- Su SGSI será único para su empresa; por lo tanto, puede que cualquier solución genérica que proporcionen fuentes externas no siempre se adapte a sus necesidades específicas y requisitos comerciales.
- Dos áreas de malentendidos y fracasos comunes son las siguientes:
 - No todos los niveles de gestión se involucran: la NTC ISO/IEC 27001 exige que todos los niveles de gestión se comprometan con el SGSI y se involucren en su operación.

-
- Su personal no se involucra activamente en la implementación del SGSI: la NTC ISO/IEC 27001 exige compromiso y participación en todos los niveles de una empresa. Por ejemplo, los consultores no pueden reemplazar a su dirección o a su personal, ni pueden gestionar su empresa, hablar, liderar o tomar decisiones en su nombre.

Implementar el SGSI por su cuenta

Teniendo en cuenta estos requisitos y los recursos disponibles, su empresa puede implementar un SGSI con o sin soporte externo; esta es una decisión que solo la dirección de la empresa puede tomar.

Es importante recordar que es su empresa la que tiene la responsabilidad principal de su propio SGSI. Esta responsabilidad no se puede delegar ni se le puede asignar a un actor fuera de la empresa, incluso si se utiliza una fuente externa, como un consultor.

No hay ninguna razón para que realice cambios significativos en la forma en que su empresa opera o gestiona su negocio. Puede ser necesario que algunos aspectos de su empresa se adapten para cumplir con los requisitos de la NTC ISO/IEC 27001, pero la forma de implementar la norma depende de su empresa. La NTC ISO/IEC 27001 es flexible y tiene la capacidad de que todas las organizaciones y empresas la utilicen. No hay ningún requisito en la NTC ISO/IEC 27001 que exija que se realicen cambios significativos en su forma actual de hacer negocios.

Usar un consultor

Si decide usar un consultor para que le ayude y lo oriente en la implementación de los requisitos de la NTC ISO/IEC 27001, es necesario que sea riguroso en su selección. Además, es necesario que tenga claro lo que un consultor puede hacer por usted y lo que no debería hacer. Un consultor le podría ayudar con una evaluación preliminar de sus actividades actuales en comparación con los requisitos de la NTC ISO/IEC 27001, y con la formación y la concientización sobre algunos aspectos de la implementación. Sin embargo, un consultor no puede ser responsable de implementar el SGSI, tomar decisiones de gestión o asumir los roles de liderazgo o la propiedad de su SGSI.

A la hora de seleccionar un consultor, su empresa debería realizar un examen exhaustivo y cuidadoso de las calificaciones, credenciales, referencias y conocimientos y experiencia en SGSI.

Es necesario que haya un entendimiento claro entre su empresa y el consultor en relación con el alcance del trabajo, los roles y las responsabilidades, las metas, los acuerdos de confidencialidad, la imparcialidad, las comunicaciones y los informes regulares y eficaces, y cualquier requisito específico de la empresa. Con el fin de inspirar la apropiación del SGSI y el compromiso con él, las personas de su empresa deberían trabajar activamente con el consultor.

Certificación del sistema de gestión de seguridad de la información

La certificación es una demostración de que su SGSI cumple con los requisitos de la NTC ISO/IEC 27001, y la emite un tercero independiente. La certificación de un SGSI no es obligatoria; es decisión de su empresa. Hay varios factores que podrían influir en su decisión; por ejemplo, uno de los clientes a los que suministra productos o servicios podría solicitar la certificación, o puede haber requisitos estatutarios o reglamentarios para la certificación, u obtener la certificación podría darle una ventaja competitiva. En el Anexo B de este manual se ofrecen más detalles sobre la certificación.

Orientaciones sobre qué significa la NTC ISO/IEC 27001 para las pymes

Según el Banco Mundial¹, las pymes representan la gran mayoría de los negocios en todo el mundo y contribuyen de manera importante al desarrollo económico mundial y a la creación de empleo. Las pymes representan alrededor del 90 % de los negocios a nivel mundial, y aproximadamente el 99 % en la Unión Europea, y, a su vez, ofrecen más de la mitad de todo el empleo. Por lo tanto, se puede decir que, en conjunto, las pymes forman el mayor conjunto de negocios de todo el mundo.

Los grupos de trabajo internacionales especializados que redactan las normas internacionales han creado dichas normas para ayudar a las

1 <https://www.worldbank.org/en/topic/sme/finance>

pymes, al igual que a las organizaciones más grandes. En particular, las pymes deberían ser capaces de compartir las ganancias y los beneficios en eficiencia y eficacia que ofrece la NTC ISO/IEC 27001.

Este manual resume brevemente los requisitos de todos los numerales de la NTC ISO/IEC 27001 y, a continuación, ofrece orientaciones para ayudar a comprender estos requisitos. Las orientaciones también incluyen ejemplos y estudios de caso.

Terminología

Al utilizar la NTC ISO/IEC 27001, tenga en cuenta que ciertas palabras y frases tienen un significado particular o específico según su contexto. Las siguientes formas verbales tienen un significado específico en la ISO y son aplicables a todos los documentos de la ISO.

Forma verbal	Definición
debe	expresar requisitos. Las palabras alternativas son las siguientes: tiene que, necesita
debería	expresar recomendaciones
puede	expresar permiso
puede	expresar posibilidad o capacidad

Para la mayoría de las palabras utilizadas en la NTC ISO/IEC 27001 se aplica la definición del diccionario, en particular para los términos comunes.

A continuación, se muestran algunos términos específicos de los sistemas de gestión de seguridad de la información, y la NTC ISO/IEC 27000 describe el vocabulario aplicado al SGSI:

Término	Definición
auditoría	proceso sistemático e independiente para obtener evidencia y para evaluarla de manera objetiva, con el fin de determinar el grado de cumplimiento los criterios de auditoría.
disponibilidad	propiedad de ser accesible y utilizable a demanda por una entidad autorizada.
competencia	capacidad para aplicar conocimientos y habilidades con el fin de lograr los resultados previstos.
confidencialidad	propiedad según la cual la información no está disponible ni se divulga a personas, entidades o procesos no autorizados
mejora continua	actividad recurrente para mejorar el desempeño.
acción correctiva	acción para eliminar la causa de una no conformidad y prevenir su recurrencia.
eficacia	grado en el cual se realizan las actividades planificadas y se logran los resultados planificados.
integridad	propiedad de exactitud y completitud.
no conformidad	incumplimiento de un requisito.
objetivo	resultado por lograr.
evidencia objetiva	datos que respaldan la existencia o veracidad de algo
desempeño	resultado medible.
requisito	necesidad o expectativa que se declara, está generalmente implícita o es obligatoria.

Término	Definición
revisión	actividad que se realiza para determinar la idoneidad, adecuación y eficacia del tema estudiado para conseguir los objetivos establecidos.
riesgo	efecto de la incertidumbre sobre los objetivos.
alta dirección	persona o grupo de personas que dirigen y controlan una organización al más alto nivel.

Cómo usar este manual

Este manual sigue la misma estructura de la NTC ISO/IEC 27001, y refleja los diez numerales de esta norma. Cada sección y subsección comenzará con un breve resumen de los requisitos de cada numeral específico de la NTC ISO/IEC 27001, y luego ofrecerá orientaciones sobre lo que esto significa y lo que una empresa debe hacer. Además, hay estudios de caso que ofrecen ejemplos sobre cómo las organizaciones pueden cumplir con los requisitos de la norma ISO/IEC 27001.

Por último, este manual no duplica los numerales de la NTC ISO/IEC 27001, de modo que el lector debería consultar los numerales aplicables de la norma cuando lea el manual.

El prólogo de la NTC-ISO/IEC 27001

El prólogo de la NTC ISO/IEC 27001 enumera los detalles técnicos de los procesos de redacción y aprobación de las normas. También explica que la NTC ISO/IEC 27001:2022 anula y reemplaza a la edición del 2013, y que ha sido revisada técnicamente para alinearla con la estructura armonizada de normas del sistema de gestión. El Anexo A de la NTC ISO/IEC 27001 también se ha revisado ampliamente y se ha alineado con los controles de seguridad de la información descritos en la norma ISO/IEC 27002:2022.

Introducción

Introducción, 0.1 Generalidades

La Introducción describe el propósito de la NTC ISO/IEC 27001, que es establecer, implementar, mantener y mejorar un SGSI. A continuación, describe los factores que influyen en la forma, la escala y la función de un SGSI, y los resultados de la implementación de un SGSI eficaz.

Esta sección agrega que la NTC ISO/IEC 27001 es una norma fundamental para los SGSI, y que forma parte de una familia de normas internacionales de la serie de normas ISO/IEC 27000.

Su forma de administrar su empresa es única para usted. La NTC ISO/IEC 27001 le ofrece un marco para crear prácticas de gestión adecuadas que se apliquen a su organización. La norma especifica los requisitos para un SGSI, que están alineados con buenas prácticas aceptadas internacionalmente para la administración de una organización.

La norma especifica un conjunto de elementos que es necesario incluir en un SGSI, pero no especifica cómo hacerlo. Por lo tanto, existe una libertad y una flexibilidad considerables para cumplir con los requisitos de seguridad de la información de la norma.

Necesita construir su SGSI en torno a las prácticas y procesos empresariales existentes, es decir, las prácticas que utiliza actualmente, de modo que el SGSI forme parte de su estructura y de sus procesos de gestión generales actuales, y que se integre en ellos.

Este numeral indica que no es necesario alinear su documentación con la estructura de numerales de la norma, ni utilizar la terminología específica que contiene; en cambio, puede usar los términos que normalmente usa en su organización.

Un SGSI busca brindar la confianza de que su empresa está preservando la confidencialidad, la integridad y la disponibilidad de la información mediante la aplicación de un proceso de gestión de riesgos. Esto, a su vez, les ofrece a las partes interesadas la seguridad de que una empresa está gestionando los riesgos adecuadamente, y de que está cumpliendo con los requisitos estatutarios y reglamentarios asociados.

Introducción, 0.2 Compatibilidad con otras normas de sistemas de gestión

Esta parte de la Introducción de la NTC ISO/IEC 27001 describe cómo la norma utiliza la estructura armonizada que ahora se aplica en todas las normas de sistemas de gestión. Esta estructura se especifica en las Directivas ISO, Parte 1, y establece un formato de diez secciones que contienen los textos obligatorios para todas las normas de sistemas de gestión.

Por lo tanto, la Estructura armonizada proporciona un marco estándar y armonizado para todos los sistemas de gestión. Esto, a su vez, ayuda a aquellas empresas que desean implementar un único sistema de gestión basado en los requisitos de dos o más normas de sistemas de gestión.

Después de la Introducción, la NTC ISO/IEC 27001 especifica diez numerales que se ajustan a la Estructura de alto nivel de la ISO. Los tres primeros numerales, que son el Objeto y campo de aplicación, las Referencias normativas y los Términos y definiciones, no contienen requisitos obligatorios. Los siete numerales restantes contienen elementos normativos u obligatorios, y, por tanto, son evaluables tanto en las auditorías internas como externas.

1. Objeto y campo de aplicación

Aquí se describe el alcance de la aplicación de la NTC ISO/IEC 27001, para los SGSI que aplican a todos los tipos y tamaños de organizaciones cuyas actividades requieren la gestión y el control de la seguridad de la información.

Orientaciones

El Objeto y campo de aplicación explica el propósito de la norma. Este numeral establece que los requisitos de la NTC ISO/IEC 27001 son para un SGSI, y centra la atención en la preservación de la confidencialidad, la integridad y la disponibilidad de la información mediante la aplicación de un proceso de gestión de riesgos que les dé la confianza a las partes

interesadas de que los riesgos se gestionan adecuadamente y que el SGSI cumple con los requisitos del cliente y con los requisitos estatutarios y reglamentarios aplicables.

También indica que la NTC ISO/IEC 27001 pretende ser genérica y aplicable a todas las organizaciones, independientemente de su tipo, su tamaño o de los productos y servicios que ofrezcan.

2. Referencias normativas

Esta numeral establece qué normas internacionales son obligatorias. En este caso, solo existe una referencia de este tipo, que es la ISO/IEC 27000, Information technology — Security techniques — Information security management systems — Overview and vocabulary

Orientaciones

Si la referencia es normativa, significa que los usuarios de la NTC ISO/IEC 27001 se tienen que referir a la referencia normativa y aplicarla. La norma ISO/IEC 27000 describe una visión general del SGSI y también describe el vocabulario para este campo de aplicación. Por lo tanto, su empresa tiene que conocer y comprender el contenido y el lenguaje de la norma ISO/IEC 27000, y utilizar el mismo lenguaje cuando se refiera a la seguridad de la información y al SGSI.

La norma ISO/IEC 27000 es una norma que contiene varias definiciones de seguridad de la información, incluidos los términos que se utilizan en la NTC ISO/IEC 27001.

Considerando que la norma ISO/IEC 27000 es una referencia obligatoria, es aconsejable que su empresa tenga acceso por lo menos a estas dos normas.

Otras referencias se enumeran en el Anexo C de este manual (Referencias).

3. Términos y definiciones

Las actividades descritas en cada norma tienen su propia terminología. La NTC ISO/IEC 27001 no enumera ninguna terminología específica, sino que se refiere a la norma ISO/IEC 27000, que incluye el vocabulario aplicado al SGSI.

Orientaciones

En muchas normas ISO, este numeral contiene una lista de términos y definiciones, necesarios para la comprensión del texto; sin embargo, dado que toda la terminología exigida para el uso de la NTC ISO/IEC 27001 se indica en la norma ISO/IEC 27000, se le remite a esa norma.

Las normas internacionales que el subcomité técnico ISO/IEC JTC 1/SC 27 ha desarrollado tanto para la gestión de la seguridad de la información como para el SGSI utilizan términos genéricos para describir la relación entre las partes interesadas implicadas.

La ISO mantiene una plataforma de navegación en línea (OBP) útil, que incluye un gran compendio de términos y definiciones, en este enlace: <https://www.iso.org/obp>.

4. Contexto de la organización

Este numeral de la NTC ISO/IEC 27001 consta de cuatro numerales:

4.1 Comprensión de la organización y su contexto

4.2 Comprensión de las necesidades y expectativas de las partes interesadas

4.3 Determinación del alcance del sistema de gestión de seguridad de la información

4.4 Sistema de gestión de seguridad de la información

Cada uno se explora por separado.

Numeral 4.1 Comprensión de la organización y su contexto

La organización tiene que determinar los problemas internos y externos que son relevantes para su propósito comercial y que tienen un efecto en sus poderes para lograr los resultados previstos de su SGSI.

La norma recomienda que los usuarios consulten la ISO 31000:2018 Risk management Guidelines, numeral 5.4.1.

Orientaciones

La intención de este numeral es comprender la empresa y su contexto mediante la determinación de los problemas externos e internos que son relevantes para el propósito comercial y la dirección estratégica de su empresa, y cómo esto podría tener un efecto en su capacidad para lograr los resultados previstos de su SGSI (es decir, la preservación de la confidencialidad, integridad y disponibilidad de la información).

Los problemas externos e internos pueden cambiar, y esto puede tener un efecto en la capacidad del SGSI para preservar la confidencialidad, la integridad y la disponibilidad de la información. Por lo tanto, se debería asegurar de que el SGSI y su contexto dentro de la empresa se monitoreen y revisen a intervalos planificados y a través de actividades como la revisión de la gestión.

La información sobre problemas externos e internos se puede recopilar a partir de muchas fuentes, como a través de documentos internos, debates y reuniones (información detallada sobre la empresa, su misión y procedimiento). Las fuentes externas de información podrían incluir prensa nacional e internacional, sitios web y departamentos gubernamentales relevantes, asociaciones de pequeños negocios y profesionales, publicaciones profesionales y técnicas, talleres y conferencias, y reuniones con clientes y otras partes interesadas. Es necesario entender y adaptar la información recopilada de fuentes externas al contexto de su empresa; solo necesita considerar lo que es importante y relevante para su empresa y evitar abrumarse por el volumen de información de fuentes externas, como los medios de comunicación y los sitios web. Es más importante tomar nota de la información de los clientes y de los proveedores con los que hace negocios.

Algunos ejemplos de problemas externos pueden incluir, entre otros:

- **factores económicos**, que pueden tener un impacto en la empresa y en su SGSI, como la economía nacional, las tasas de cambio, las tasas de interés, la inflación, la disponibilidad de crédito, los salarios, los costos de transporte;
- **factores sociales**, como las tasas de desempleo, los requisitos de seguridad, los niveles de educación, el público, la cultura;
- **condiciones políticas**, como la estabilidad política, las inversiones públicas, la infraestructura local, los acuerdos comerciales internacionales;
- **tendencias tecnológicas** que pueden tener un impacto en la empresa y en su SGSI; estas podrían ser nuevas tecnologías que su empresa adopta, nuevas versiones de software, materiales y equipos, o expiración de patentes;
- **relaciones contractuales**, entendiendo sus relaciones con clientes y proveedores, y considerando sus requisitos de seguridad de la información cuando sea apropiado para la prestación de servicios y productos;
- **factores del mercado**, incluida la cuota de mercado, las tendencias del mercado, las tendencias de crecimiento de los clientes, los problemas nacionales y globales, la estabilidad del mercado, las relaciones de la cadena de suministro;
- **factores estatutarios y reglamentarios** que afectan el negocio, como las reglamentaciones de privacidad, las leyes de ciberseguridad, el derecho laboral, las regulaciones de competencia, las restricciones de importación/exportación, la ley de propiedad intelectual, las regulaciones sindicales y las regulaciones relacionadas con una industria específica.

Los problemas internos pueden incluir:

- el **desempeño** general de la empresa;
- **factores de recursos**, incluida la infraestructura y el entorno para el funcionamiento del SGSI;
- **aspectos humanos**, incluida la competencia de las personas, la cultura de la empresa, las relaciones con los sindicatos;

-
- **factores operativos**, como las capacidades de proceso/producción y prestación de servicios, el desempeño del SGSI, el seguimiento de la satisfacción del cliente;
 - **gobernanza de la organización**, como las reglas y los procedimientos para la toma de decisiones o la estructura organizacional.

El enfoque que adopte su empresa para establecer el contexto y determinar los problemas es una decisión completamente suya. Un enfoque simple puede ser útil para su empresa (dependiendo del tamaño y la complejidad de su negocio), tales como las lluvias de ideas en reuniones y las preguntas de “¿qué pasaría si...?”. Su empresa puede decidir utilizar una herramienta de análisis FODA (fortalezas, oportunidades, debilidades y amenazas).



Estudio de caso

Una pequeña empresa que importa bienes para distribuir en el comercio de servicios de vehículos es parte de una cadena de suministro. Maneja varios tipos de información, incluida la de los proveedores extranjeros, los exportadores, los sistemas de control fronterizo y los clientes. La empresa debería determinar cualquier problema externo que pueda afectar a la capacidad del SGSI para proteger esta información.



Estudio de caso

Una empresa pequeña presta servicios de transporte a escuelas y está implementando un SGSI para proteger toda la información relacionada con la prestación de estos servicios y de sus clientes. El gobierno local tiene varios requisitos relacionados con la seguridad de los niños que la empresa necesita cumplir.



Estudio de caso

Una pequeña residencia para personas mayores que ofrece alojamiento, asistencia profesional las 24 horas, servicios de apoyo para necesidades médicas especiales y otros servicios de apoyo. La residencia para personas mayores maneja una gran cantidad de información sensible y personal, incluidos datos médicos, datos financieros y datos personales relacionados con sus pacientes. La residencia está implementando un SGSI para proteger toda la información relacionada con sus pacientes, personal y cuidadores. Es posible que la empresa tenga que cumplir con varias normativas gubernamentales y el SGSI tenga que incluir disposiciones para estas normativas

Numeral 4.2. Comprensión de las necesidades y expectativas de las partes interesadas

La organización tiene que determinar qué partes interesadas son relevantes para el SGSI, además de sus requisitos y de cuáles de estos requisitos es necesario abordar dentro del SGSI.

Orientaciones

La intención de este numeral es asegurar que su empresa considere los requisitos relevantes de todas las partes interesadas relevantes. Esto abarca más que solo los de sus clientes inmediatos y ayuda a centrar la atención en aquellas partes que tienen un interés en su empresa, y que podrían tener un impacto en su SGSI. El numeral 4.1 de la NTC ISO/IEC 27001 ayuda a determinar las partes interesadas relevantes.

Por lo general, cada empresa puede tener un conjunto diferente de partes interesadas, por lo que su empresa tendrá un conjunto relativamente distinto de partes interesadas. Una parte interesada se puede identificar según su posible influencia o impacto en el desempeño de su empresa y en las decisiones que necesita tomar. Por supuesto, las decisiones que tome una parte interesada pueden afectar a su empresa.

Una parte interesada puede crear riesgos para su SGSI, por ejemplo, un miembro de una cadena de suministro, conectado a su sistema, cuya seguridad no sea buena. Otra consideración a la hora de determinar una parte interesada podría ser su posible influencia o impacto en el mercado.

Algunos ejemplos de partes interesadas internas son los siguientes:

- propietarios;
- accionistas;
- empleados;
- personal.

Algunos ejemplos de partes interesadas externas son los siguientes:

- clientes;
- socios comerciales;
- proveedores externos;
- usuarios;
- otras personas que trabajen para la empresa;
- banqueros y proveedores de seguros;
- autoridades estatutarias y reglamentarias;
- titulares de propiedad intelectual;
- sindicatos;
- asociaciones comerciales;
- competidores.

La comprensión de las necesidades y expectativas de las partes interesadas se puede lograr de diferentes maneras. Por ejemplo, con la consulta a los clientes y proveedores, la realización de encuestas a los usuarios, la revisión de las relaciones de la cadena de suministro, la revisión de los requisitos reglamentarios y la consideración de la retroalimentación que se reciba sobre las partes interesadas, la vigilancia del mercado y el monitoreo de las necesidades de los clientes.



Estudio de caso

Una pequeña escuela de idiomas internacional tiene estudiantes de todo el mundo que aprenden inglés y francés. La edad de los estudiantes es de 11 años en adelante. Los cursos que ofrece la escuela se imparten a través de enseñanza presencial y enseñanza en línea. Esta maneja varios tipos de información relacionada con sus estudiantes (incluidas las necesidades especiales, las expectativas), las admisiones y la administración de la escuela. Es necesario que la escuela se asegure de que comprende las necesidades y expectativas de los estudiantes, padres y tutores y los requisitos de las autoridades educativas, los organismos reguladores y las agencias de control fronterizo (por ejemplo, visa de estudiante) con el fin de proteger la información que maneja de manera apropiada y adecuada.

Numeral 4.3. Determinación del alcance del sistema de gestión de seguridad de la información

Este numeral exige que la organización determine el alcance de su SGSI a partir de la consideración del contexto, las partes interesadas y las conexiones y dependencias de las actividades que realizan la organización y otras organizaciones.

Orientaciones

La intención de este numeral es que su empresa determine los límites de su SGSI. Estos límites se tienen que definir de manera que ayuden a su organización a satisfacer los requisitos de la NTC ISO/IEC 27001 y los objetivos de su SGSI.

Esto significa que, de acuerdo con los ítems a) y b) del numeral 4.3 de la NTC ISO/IEC 27001, su empresa debería establecer el alcance según los problemas externos e internos que se hayan determinado de acuerdo con los requisitos del numeral 4.1 de la NTC ISO/IEC 27001, y según los requisitos relevantes de las partes interesadas relevantes que se hayan determinado de acuerdo con los requisitos del numeral 4.2 de la NTC ISO/IEC 27001.

Según el ítem c) del numeral 4.3 de la NTC ISO/IEC 27001, la empresa también debería establecer los límites del SGSI a partir de la consideración de la infraestructura de la organización, de si tiene más de una sede, de sus actividades, de cualquier política comercial que tenga y de si sus actividades, procesos y servicios se proporcionan de forma interna o externa.

El alcance se debería registrar y mantener como información documentada. El alcance debería incluir detalles de todo lo que cubre un SGSI. Esta información documentada se puede mantener con cualquier método que su empresa determine apto para satisfacer sus necesidades, ya sea manual o electrónico.



Estudio de caso

Un pequeño librero independiente importa y vende libros en muchos países. Al considerar el alcance del SGSI del librero, los factores relevantes pueden incluir los siguientes: hay dos sedes para sus operaciones, es decir, una oficina y una instalación de almacenamiento; trabaja con editoriales (nacionales y extranjeras), librerías de segunda mano, subastadores de libros antiguos, y otros proveedores, empresas de logística y clientes de libros.

Numeral 4.4. Sistema de gestión de seguridad de la información

Este numeral declara que la organización debe establecer, implementar, mantener y mejorar continuamente un SGSI, aplicando los requisitos de la NTC ISO/IEC 27001.

Orientaciones

La intención de este numeral es garantizar que usted establezca, implemente, mantenga y mejore continuamente un SGSI de acuerdo con la NTC ISO/IEC 27001. Esto incluye los procesos necesarios para la implementación efectiva del sistema, tales como la evaluación de los riesgos, el tratamiento de los riesgos, el seguimiento, la auditoría interna, la revisión de la gestión y otros, de acuerdo con los requisitos de la NTC ISO/IEC 27001.

Un proceso es una serie de acciones o pasos que buscan alcanzar un fin en particular. Cada proceso utilizará un conjunto de entradas con el fin de producir un resultado previsto. El nivel en el que es necesario detallar los procesos puede variar de acuerdo con el contexto de la empresa y la aplicación del riesgo; con la consideración del grado en que el proceso afecta la capacidad de su empresa para lograr los resultados previstos, la probabilidad de que ocurran problemas con el proceso y las posibles consecuencias de dichos problemas.

Un proceso es un conjunto de actividades interrelacionadas o que interactúan entre sí y que utilizan insumos y productos para obtener los resultados previstos. Por ejemplo, los insumos necesarios para planificar el SGSI (NTC ISO/IEC 27001, numeral 6.1) incluyen aspectos a los que se hace referencia en el numeral 4.1 de la NTC ISO/IEC 27001, y requisitos a los que se hace referencia en el numeral 4.2 de la NTC ISO/IEC 27001. Esto determinará los riesgos y oportunidades que se deben abordar. En concreto, para lograr los siguientes fines:

- garantizar que el SGSI pueda alcanzar sus objetivos;
- prevenir o reducir los efectos indeseados;
- alcanzar la mejora continua.

El producto de este proceso incluye las acciones necesarias para abordar los riesgos y las oportunidades. Los procesos exigidos para la evaluación del riesgo están cubiertos en detalle en el numeral 6.



Estudio de caso

Un productor de queso quiere cumplir con los requisitos de la NTC ISO/IEC 27001:2022. Ya cuenta con seguridad de la información, que incluye mantener parte de su información comercial en forma de papeles, archivos y carpetas, que se mantienen seguros y protegidos de forma física, y sus edificios, tiendas y oficinas están seguros de forma física. Este ha comenzado a utilizar TI para almacenar y procesar una mayor parte de su información de manera electrónica y ha comenzado a promocionar y vender algunos de sus quesos en línea. También se está expandiendo para abrir más tiendas.

El productor tiene reuniones internas para examinar todo en su negocio con el fin de determinar los problemas (NTC ISO/IEC 27001:2022, numeral 4.1) y los requisitos (NTC ISO/IEC 27001:2022, numeral 4.2) para comprender sus planes de negocio y a futuro relacionados con sus actividades de producción de queso o para registrar que las tareas se realizaron como se exigía. Esto incluye revisar la información que tiene, tanto en papel como electrónicamente: qué información es vital y necesaria para su futuro negocio, qué información no es vital, pero se debería conservar, y qué información se puede descartar.

La revisión incluye la identificación de qué información es sensible o confidencial para la empresa y qué información está disponible públicamente (por ejemplo, información en el sitio web que promociona sus productos), además de los requisitos para proteger la información.

5. Liderazgo

El numeral 5 de la NTC ISO/IEC 27001 incluye tres numerales con requisitos para el liderazgo:

5.1 Liderazgo y compromiso

5.2 Política

5.3 Roles, responsabilidades y autoridades de la organización

Numeral 5.1 Liderazgo y compromiso

Este numeral especifica ocho acciones que la alta dirección debe implementar para proporcionar liderazgo con el fin de garantizar la eficacia general del SGSI.

Orientaciones

La intención de este numeral es demostrar el liderazgo de la dirección y su compromiso con el SGSI. Lo hace mediante la exigencia de que la dirección esté directamente involucrada en ciertas actividades.

La dirección de la empresa debería saber lo que quiere que logre su empresa. Y debería ser igual respecto a la seguridad de la información: debería haber una visión clara de qué logros se desea alcanzar mediante un SGSI. Una buena seguridad de la información es una inversión, porque costará dinero y tiempo, pero la recompensa debería ser un negocio más seguro y exitoso. La NTC ISO/IEC 27001 se refiere a lo que la dirección de la empresa quiere alcanzar como objetivos, y a la política, que es la declaración general de intenciones que describe lo que la empresa hará para alcanzar estos objetivos. El requisito es que la alta dirección de la empresa tiene que garantizar que la política de seguridad de la información de la empresa refleje su intención y dirección.

Ejemplos

Un objetivo podría ser “no divulgar información personal de manera inapropiada”; una política correspondiente podría ser “los computadores portátiles tienen que usar cifrado de disco duro”.

La seguridad de la información nunca debería ser una ocurrencia tardía. Esto es lo que se entiende por “integración”. Esta debería ser una parte natural de las operaciones diarias. Por lo tanto, la dirección de la empresa se debería animar (y debería animar a todos los que trabajan bajo su dirección) a “pensar en la seguridad primero” en todo su trabajo.

Ejemplos

La evaluación del riesgo debería constituir un primer paso natural en cualquier nueva iniciativa. La revisión de los resultados de cualquier actividad y la búsqueda de mejoras también debería ser algo natural.

El funcionamiento de un SGSI eficaz exige tiempo y esfuerzo. Por lo tanto, la dirección de la empresa tiene que garantizar que haya recursos adecuados, incluido el presupuesto para tecnología y personal, y que las personas tengan la competencia necesaria para desempeñar su trabajo. Si esto no se hace, las actividades planificadas no se llevarán a cabo a tiempo y el SGSI nunca cumplirá sus objetivos. Por supuesto, si la empresa es una entidad unipersonal, entonces esta persona es responsable de todos los requisitos de los ítems d), f) y h) del numeral 5.1 de la NTC ISO/IEC 27001.



Estudio de caso

Un fotógrafo dirige una empresa unipersonal de fotografía y es responsable de todo, desde el marketing y las ventas hasta de tomar las fotografías y de presentar la declaración de renta. El fotógrafo ha invertido en una cámara digital de alta gama y en un equipo informático móvil, y hace uso de los servicios en la nube para el almacenamiento, el procesamiento y las comunicaciones con los clientes. Entre sus clientes se encuentran compañías de periódicos y televisión.

El fotógrafo opera un SGSI móvil para ayudar con la gestión de seguridad de la información, que se considera parte integral de las operaciones comerciales. El fotógrafo contrató a un consultor para que le ayudara a construir el SGSI y garantizara que este se integrara plenamente en el flujo de trabajo y no lo distrajera de concentrarse en el negocio de tomar fotografías de interés periodístico y obtener ganancias.

La dirección de la empresa debería ser plenamente consciente del rendimiento del SGSI y actuar según sea necesario para garantizar que cumpla sus objetivos.



Estudio de caso

Un pequeño consultorio médico consta de cinco médicos, cuatro enfermeras, un director del consultorio y tres recepcionistas. El médico de mayor antigüedad actúa como gestor del SGSI y, preocupado por la confidencialidad, integridad y disponibilidad de los datos médicos, ha asumido la responsabilidad personal del SGSI. Se llevan a cabo reuniones semanales antes de abrir el consultorio para los pacientes, en las que el médico de mayor antigüedad garantiza que se discutan todos los asuntos relevantes para la seguridad de la información.

En las empresas que constan de más de una persona, es importante que la dirección de la empresa dé ejemplo de cómo exige que otras personas se comporten. También es importante que todos sepan por qué la empresa tiene un SGSI y qué puede suceder si la empresa no lo cumple. El personal de la empresa debería entender por qué las cosas se deberían realizar de cierta manera y cómo se deberían realizar. Al saber por qué, las personas pueden usar su iniciativa cuando algo que se supone que deben hacer no se puede hacer, pero existe una alternativa que lleva al mismo resultado.



Estudio de caso

Una empresa de electrónica tiene un contrato con el gobierno. La última persona en salir tiene que guardar todos los documentos marcados como "confidenciales" en la caja fuerte número 1. El propósito de este procedimiento es salvaguardar los secretos gubernamentales. Sin embargo, una noche, el miembro del personal descubre que no lo puede llevar a cabo porque la cerradura está rota.

Como entiende el propósito del procedimiento, el empleado busca otra caja fuerte con una cerradura que funcione y con suficiente espacio para acomodar todo el contenido de la caja fuerte número 1. La caja fuerte número 3 es adecuada.

El empleado transfiere el contenido de la caja fuerte número 1 a la caja fuerte número 3, junto con los documentos "confidenciales" que para guardar y la bloquea. Finalmente, el empleado deja una nota en la caja fuerte número 1, donde explica lo que ha hecho y por qué. Conoce la importancia de este último paso. A la mañana siguiente, sus compañeros encontrarán la caja fuerte número 1 abierta y vacía. Sin la nota, podrían llegar a la conclusión errónea de que ha ocurrido un robo y dar la alarma.

La dirección de la empresa también debería alentar y apoyar a todos los que participan en las actividades del SGSI. Se debería alentar a la dirección subordinada a emular el comportamiento de la dirección de la empresa. De esta manera, los beneficios de liderar con el ejemplo se extienden a toda la empresa.



Estudio de caso

Después de haber aprendido a realizar una evaluación del riesgos, un agente de policía de alto rango decidió comprar una caja fuerte y guardar bajo llave todos sus documentos confidenciales durante la noche. La noticia de lo que hizo el agente de alto rango se extendió rápidamente por todo el departamento. En una semana, todos los agentes subordinados compraron cajas fuertes para ellos y su personal, de modo que también pudieran asegurar sus documentos durante la noche.

Esta motivación y este apoyo no sólo demuestran el compromiso de la dirección de la empresa con la seguridad de la información, sino que también les proporciona retroalimentación vital a todos de que están haciendo lo que se exige de ellos. Esto facilita la recompensa, cuando está justificada. La dirección de la empresa también debería animar a las personas a reportar errores, equivocaciones e incidentes, ya que la detección temprana puede evitar desastres, crear conciencia y conducir a mejoras en el SGSI.



Estudio de caso

La entrada a la oficina se controla mediante tarjetas de acceso. Luego de salir de una reunión social después del trabajo, un empleado descubrió que había perdido su tarjeta de acceso. Inmediatamente llamó a su superior y le informó de lo sucedido. El superior pudo anular el registro de la tarjeta de forma inmediata. Por lo tanto, nadie podía utilizarla para acceder a la oficina. Al día siguiente, se le recordó al empleado que tuviera más cuidado, pero aun así se le felicitó por su acción rápida al reportar el incidente. No ocurrió ningún daño.

La dirección de la empresa siempre debería buscar mejoras: objetivos más gratificantes, operaciones más eficientes, mayor satisfacción personal y del cliente. Las ideas de mejora pueden venir de cualquier lugar y de cualquier persona.

Ejemplos

La gerencia de una empresa se da cuenta de que los eventos mundiales pueden tener un impacto en sus operaciones comerciales. Por lo tanto, la dirección añade un elemento a las reuniones periódicas de gestión para tomar nota de los eventos mundiales recientes y determinar su impacto, si lo hubiera, en la empresa y sus preocupaciones de seguridad de la información. Si bien hay muchos eventos mundiales que no tienen ningún impacto en la empresa, ya no existe el riesgo de dejar pasar los que sí lo tienen.

Numeral 5.2 Política

Este numeral exige que la organización establezca una política, y especifica los detalles que se tienen que incluir dentro de la política del SGSI.

Orientaciones

La intención de este numeral es exigirle a la dirección de la empresa que registre lo que desea que logre su empresa y cómo quiere que se aborde. La política tiene que ser un reflejo fiel de lo que la dirección de la empresa quiere que el SGSI logre y cómo quiere que lo haga. Debería ser apropiado para sus propósitos comerciales.



Estudio de caso

El director de una empresa de consultoría de TI unipersonal tiene un SGSI. Su política tiene secciones para proveedores de servicios en la nube; operación del software como servicio de la empresa; sitio web público de la empresa; respaldo de información; recordatorios de contraseñas; actualizaciones críticas y programas malignos; seguridad inalámbrica y de punto final; retención de registros; eliminación de medios de comunicación; información en tránsito; trabajo fuera de la oficina, y brechas de seguridad.

La dirección de la empresa puede incluir los objetivos de seguridad de la información de la empresa en la política o escribir la forma en que se deben determinar.



Estudio de caso

El propietario de un taller de motocicletas de cinco personas revisa el desempeño del taller cerca del final de cada año presupuestario y establece nuevos objetivos comerciales para el año siguiente. A continuación, el propietario establece nuevos objetivos de seguridad de la información que respalden estos objetivos comerciales, de acuerdo con los incidentes y la retroalimentación del personal y los clientes del taller. La política de seguridad de la información del taller describe la forma en la que la dirección de la empresa establece los objetivos de seguridad de la información para la empresa.

Si bien la mejor manera para que la dirección de la empresa demuestre su compromiso es por medio de acciones, se recomienda una declaración de política sencilla, del tipo “[Nombre de la empresa] está comprometida...”. Del mismo modo, la dirección de la empresa puede demostrar mejor su compromiso con la mejora continua por medio de acciones. Sin embargo, se recomienda una declaración de política sencilla, como “[Nombre de la empresa] está comprometida...”.

La política de información tiene que estar documentada, y la empresa puede decidir exactamente cómo hacerlo, por ejemplo, de forma digital, con una copia impresa, o en ambos formatos.

Ejemplos

Puede ser un documento llamado “Política de seguridad de la información”. Puede ser parte de un documento llamado “Manual de operaciones”, puede ser una página web o incluso puede estar publicada en una pared.

En las empresas que constan de más de una persona, como la dirección de la empresa quiere que todos obedezcan la política de seguridad de la información, esta tiene que informarlos primero.

También es posible que personas ajenas a la empresa necesiten estar al tanto de la política, ya sea porque necesitan verla antes de comerciar con la empresa o porque la empresa quiere que la cumplan. En cualquier caso, la empresa debería ser capaz de decidir qué partes está dispuesta a poner a disposición, cómo y a quién.



Estudio de caso

Una pequeña compañía de taxis tiene contratos con el concejo local para llevar a niños con discapacidades físicas y mentales a varias escuelas de necesidades especiales. Los conductores son debidamente examinados y están capacitados en cómo cuidar a sus pasajeros en caso de un accidente o una emergencia médica. Por lo tanto, el consejo tiene interés en los detalles de la política de SGSI de la compañía de taxis, que la empresa pone a su disposición en su totalidad.

Numeral 5.3 Roles, responsabilidades y autoridades de la organización

Este numeral exige que la alta dirección asigne y comunique todas las responsabilidades y autoridades que corresponden a los roles relevantes para el SGSI. También existen requisitos para garantizar la responsabilidad y la autoridad, de modo que el SGSI cumpla con los requisitos de la NTC ISO/IEC 27001, y para reportarle a la alta dirección sobre el desempeño del SGSI.

Orientaciones

La intención de este numeral es exigirle a la dirección de la empresa que asigne la responsabilidad del SGSI.

La dirección de la empresa puede determinar y asignar las responsabilidades y autoridades que considere necesarias para la buena operación del SGSI. Sin embargo, la NTC ISO/IEC 27001 pide que se asignen dos roles especiales. Si la dirección de la empresa asume la responsabilidad cotidiana del SGSI, entonces la dirección de la empresa se debería asignar a sí misma estos dos roles especiales. De no ser así, sería conveniente asignárselos a la persona que pongan a cargo del SGSI.



Estudio de caso

En un negocio de logística de sesenta personas, el director general es propietario del SGSI y preside las reuniones de revisión de la gestión. Sin embargo, el director de calidad tiene la responsabilidad de garantizar la conformidad con el manual de calidad y seguridad de la información y de reportarle formalmente a la junta directiva sobre la calidad y el desempeño la seguridad de la información.i

6. Planificación

El numeral 6 de la NTC ISO/IEC 27001 especifica los requisitos para la planificación y consta de tres numerales:

6.1 Acciones para abordar los riesgos y las oportunidades

6.2 Objetivos de seguridad de la información y planificación para alcanzarlos

6.3 Planificación de los cambios

El primer numeral se divide en tres subnumerales; el primero describe los requisitos generales, mientras que el segundo y el tercero especifican los requisitos para la evaluación y el tratamiento del riesgo, respectivamente.

Numeral 6.1 Acciones para abordar riesgos y oportunidades

6.1.1 Generalidades

La organización tiene que examinar el contexto de la organización según los numerales 4.1 y 4.2, y luego definir los riesgos y las oportunidades que la organización necesita abordar. Esto busca minimizar o eliminar la posibilidad de que aparezcan riesgos que comprometan la operación efectiva del SGSI, y también capitalizar cualquier oportunidad que beneficie al SGSI.

Orientaciones

Este numeral exige que una empresa determine y aborde los riesgos y las oportunidades asociadas con las necesidades y expectativas de las partes interesadas. Estas partes incluyen a los clientes, usuarios y reguladores. El riesgo tiene muchas definiciones; sin embargo, a los efectos de este manual, se puede entender como una situación que puede exponer a la empresa a consecuencias perjudiciales que podrían tener un impacto negativo. Dichos impactos, a su vez, podrían afectar gravemente las finanzas, la reputación, las operaciones, a los clientes o a los usuarios de la empresa.

El riesgo se puede expresar en términos de las fuentes que causan el riesgo, el efecto o las consecuencias de esta causa y la probabilidad de que se presente. La causa podría ser un incidente, como un intento no autorizado de acceder a la información que termine en un robo de información. En términos simples, generalmente el riesgo se expresa como la posibilidad de que un incidente (como el acceso no autorizado a su información) explote las vulnerabilidades (debilidades) de su sistema de control de acceso, y termine en el robo de información.

Es importante tener en cuenta que las actividades comerciales proporcionan beneficios y oportunidades, y estos se deberían considerar junto con los riesgos de seguridad de la información. Las empresas utilizan la información para llevar a cabo sus negocios y alcanzar sus metas y objetivos comerciales. Por ejemplo, para extender el negocio, ofrecer servicios más rápidos y mejores, o para presentar una ventaja competitiva en el mercado. Sin embargo, es importante controlar los riesgos de esta información. Por lo tanto, una empresa necesita lograr un equilibrio entre el control de los riesgos de la seguridad de la información, pero no hasta el punto de que se reduzcan las oportunidades.

Su empresa necesita abordar los problemas y requisitos relevantes para su negocio que se determinan en los numerales 4.1 y 4.2 de la NTC ISO/IEC 27001, y, posteriormente, determinar los riesgos y las oportunidades, para garantizar que el SGSI puede alcanzar el o los resultados previstos, con el fin de prevenir o reducir los efectos no deseados y lograr una mejora continua.



Estudio de caso

Una clínica comunitaria de reciente creación presta servicios médicos a 29 000 pacientes. Algunos de sus computadores están conectados a través de internet a farmacias, otros centros locales de salud, un hospital local y el servicio de salud del gobierno central. Uno de los principales requisitos que tiene esta clínica es la protección de la historia clínica de sus pacientes. La mayoría de estas historias clínicas se almacenan electrónicamente, pero algunas más antiguas de otras clínicas están en papel. Otro requisito es proteger el acceso a sus computadores y las conexiones a internet. Será necesario que la clínica determine los riesgos a los que se enfrenta mediante una evaluación del riesgo.

Es necesario que su empresa adopte un plan que especifique las acciones para abordar los riesgos y las oportunidades. También será necesario que el plan especifique cómo pretende integrar e implementar las acciones en sus procesos del SGSI y cómo evaluará la eficacia de estas acciones.

6.1.2 Evaluación de riesgos de seguridad de la información

Este numeral exige que una empresa tenga un proceso sistemático para determinar los riesgos para la seguridad de la información de su negocio, y para luego evaluar estos riesgos considerando tanto las posibilidades de que ocurra un incidente como la gravedad de las consecuencias. La empresa necesita documentar este proceso en un procedimiento.

Orientaciones

La intención de este numeral es definir un proceso de evaluación del riesgo para la seguridad de la información. Es necesario que su empresa decida qué métodos y criterios utiliza para identificar, analizar y evaluar los riesgos, incluidos los criterios para aceptar el nivel de riesgo. Cualquiera que sea el método que se adopte, este tiene que permitir que las valoraciones y revaloraciones del riesgo arrojen resultados repetibles, válidos, coherentes y comparables. La NTC ISO/IEC 27001 proporciona mucha flexibilidad para que su empresa seleccione el método más adecuado para su negocio. El método utilizado debería ofrecerle una comprensión de los riesgos que enfrenta la empresa, por lo general, en términos de causas y efectos del riesgo (consecuencias e impactos), y de la probabilidad de que se presente el riesgo, los niveles de riesgo y los criterios para decidir si el nivel de riesgo es aceptable.

a) Defina y documente los criterios de aceptación del riesgo

La NTC ISO/IEC 27001 utiliza el término criterios para referirse a un principio o norma según el cual algo se puede juzgar o decidir. Su empresa define los criterios de aceptación del riesgo, que se refieren al nivel de riesgo que la empresa está dispuesta a aceptar. Estos criterios dependerán del apetito de riesgo de la empresa, es decir, del nivel de riesgo que la empresa esté dispuesta a perseguir y tolerar. También depende de los riesgos para los objetivos empresariales, para los cuales es necesario tener en cuenta los intereses y requisitos internos y externos, las normas relevantes que podrían aplicar a la empresa y las leyes y reglamentos aplicables.

Los criterios de aceptación del riesgo se pueden basar en la probabilidad de que se presente el riesgo y en sus consecuencias o impactos, pero se pueden ampliar para considerar otros factores, como el equilibrio costo-beneficio entre las pérdidas prospectivas y el costo de los controles.

b) Desarrolle criterios para realizar valoraciones de los riesgos de seguridad de la información

Los criterios para realizar una evaluación del riesgo especificarán cómo se determina la importancia del riesgo, en términos de sus consecuencias, probabilidad y nivel de riesgo.

En la NTC ISO/IEC 27001:2022 nos preocupamos por las consecuencias que directa o indirectamente impactan la preservación o pérdida de la confidencialidad, integridad y disponibilidad de la información. Por lo tanto, los criterios sobre las consecuencias se deberían elaborar y definir en términos del nivel de daño o pérdida, o del perjuicio para la empresa que resulte de la pérdida de confidencialidad, integridad y disponibilidad de la información.

A la hora de definir los criterios sobre las consecuencias, se deberían tener en cuenta especialmente los siguientes aspectos:

- pérdida de vidas humanas o daños a individuos o grupos;
- pérdida de personal y de capital intelectual;
- pérdidas financieras;
- pérdidas operativas, pérdidas de productividad, fallos del sistema, daños a un proceso comercial;

-
- pérdida de ventaja comercial o de cuota de mercado;
 - daños a la confianza o reputación públicas;
 - violaciones de requisitos legales, reglamentarios o estatutarios;
 - violaciones de contratos o niveles de servicio.

Una empresa con apetito de riesgo elevado puede establecer un umbral más alto de aceptación, lo que significa que acepta más riesgos que una organización con un apetito de riesgo más bajo.

Los criterios de riesgo se deberían revisar y actualizar según sea necesario, como resultado de cualquier cambio en el contexto de la gestión de riesgos de seguridad de la información.

El nivel de dirección autorizado debería aprobar los criterios de aceptación del riesgo.

Ejemplos

Los riesgos asociados con una violación de datos dependerán del tipo de datos. Si se trata de datos sensibles, puede tener un impacto en los datos personales y pueden dar lugar al incumplimiento de la legislación aplicable en materia de protección de datos personales, por ejemplo; mientras que, si se trata de datos críticos, como datos financieros, como códigos de acceso y números de cuenta, puede tener un impacto grave en procesos y operaciones comerciales. De forma alternativa, el impacto de una violación de datos podría conllevar un incumplimiento de contrato, un daño a la confianza del cliente o la pérdida de una ventaja comercial.

La probabilidad de que se presente el riesgo dependerá de diferentes criterios. Por ejemplo, si se trata de

- un evento natural;
- un evento accidental o un error humano;
- un fallo tecnológico;
- un grado de exposición a una amenaza;
- un grado de vulnerabilidad o debilidad.

La probabilidad de un incidente se puede expresar en términos de las posibilidades de que algo ocurra, por ejemplo, como viabilidad, frecuencia o eventualidad. Las posibilidades de fallo del sistema, del hardware o de la red se pueden expresar en términos numéricos, mientras que es más probable que el error humano o el grado de exposición o debilidad se expresen cualitativamente.



Estudio de caso

Un pequeño negocio de consultoría ayuda a las empresas con apoyo en la gestión de proyectos. Lleva a cabo un ejercicio de evaluación del riesgo para su propio negocio y utiliza la siguiente escala cualitativa de probabilidad para su análisis de riesgos:

Impacto

- Muy alto (crítico, amenaza la supervivencia del negocio)
- Alto (pérdidas, daños, perjuicios importantes o significativos)
- Medio (pérdidas, daños, perjuicios moderados)
- Bajo (pérdidas menores, daños, perjuicios)
- Muy bajo (muy pocas pérdidas, daños, perjuicios)

Probabilidad (descripción)

- Muy alta (80 %: seguramente ocurrirá)
- Alta (50 %-60 %: hay altas posibilidades de que ocurra)
- Media (25 %: hay posibilidades de que ocurra)
- Baja (10 %: puede ocurrir)
- Muy baja (menos del 1 %: hay muy pocas posibilidades de que ocurra)

c) Identifique el riesgo

Esta etapa del proceso de evaluación implica la identificación de lo que podría suceder que pueda tener un impacto en el SGSI de su empresa. Es necesario que considere los diversos tipos de eventos que podrían ocurrir y que pueden resultar en un riesgo. A veces estos se clasifican como incidentes de seguridad, por ejemplo, un ataque de piratería informática; posibles violaciones, como las fallas en mantener segura su información confidencial o comercial de conformidad con su política de seguridad de la información, que terminen en la filtración de esta información al público; o peligro para la seguridad por falta de concientización del personal.

Su empresa tendrá información en varios formatos, almacenada y procesada de diferentes maneras, por ejemplo, información en papel almacenada en archivadores, formatos electrónicos como bases de datos, discos duros o dispositivos USB, sitios web o en la nube. Todas estas formas diferentes de almacenar la información están sujetas a incidentes de seguridad, violaciones o peligros que pueden resultar en la pérdida de confidencialidad, integridad y disponibilidad de la información. Una forma común de identificar los riesgos es considerar las posibles amenazas y vulnerabilidades que podrían estar relacionadas con sus activos de información. Una vulnerabilidad es una debilidad que un atacante podría explotar, por ejemplo, un pirata informático podría explotar la debilidad en su método de control de acceso para obtener acceso no autorizado a su información.



Estudio de caso

Una pequeña firma de logística que depende en gran medida de las TI y de los dispositivos móviles para hacer sus negocios ha identificado las siguientes amenazas e incidentes relevantes para su negocio:

- **Incidentes de virus**, es decir, que un virus podría infectar su sistema a través de correo electrónico, un clic a enlaces a sitios web, CD y dispositivos de memoria USB infectados.
- **Uso inadecuado** de la tecnología que usa la empresa por parte del personal, incluido el uso del correo electrónico y de internet para fines no laborales.
- **Acceso no autorizado**, que implica que alguien obtenga acceso a sus sistemas informáticos sin su permiso o consentimiento. Puede ser una

amenaza interna o externa. En muchos países, piratear una computadora es un delito penal. Sin embargo, no debería depender únicamente en la legislación para protegerse. Aunque la ley podría disuadir a los piratas informáticos, usted tiene que implementar sus propios controles adicionales de seguridad para evitar el acceso no autorizado. El impacto de esta amenaza incluye el robo de información, la eliminación de información, la modificación de la información, el cambio de la configuración de su computador o el acceso a información personal.

- **Pérdida de datos**, que puede implicar una pérdida accidental o deliberada. El almacenamiento de datos, ya sea en papel o en formato electrónico, puede ser vulnerable al robo de datos o a daños físicos. Es importante implementar copias de seguridad de sus datos para que su empresa pueda continuar haciendo negocios, aunque el computador se dañe y los datos del computador se pierdan.
- **Robo**, que puede adoptar muchas formas, como el robo de dinero información, equipos, material protegido por derechos de autor, datos personales, identidad o datos de tarjetas de crédito.

Robo externo: el robo de información es un delito penal y se debería denunciar ante la policía. Estas situaciones no siempre son directas; por ejemplo, estos tipos de amenazas podrían poner de manifiesto las vulnerabilidades de los procedimientos internos de la empresa y pueden dar lugar a una pérdida de reputación. Este tipo de robo se debería manejar con mucho cuidado.

Robo interno: el robo interno necesita una consideración y un manejo cuidadosos. Los procedimientos internos deberían determinar qué hacer en tales circunstancias. Además, se debería consultar a recursos humanos.

- **Fallos del sistema, desastres e interrupciones**, que pueden resultar de (i) fallos del hardware y el software de las TI, a causa de falta de mantenimiento, mal funcionamiento de los componentes, parches de software desactualizados, actualizaciones o riesgos físicos, (ii) infecciones de virus, que provocan la destrucción de archivos, ralentización del software o de los sistemas, sobrecargas o caídas, (iii) un ataque de piratería, que termina en un acceso no autorizado a los archivos del sistema, en la eliminación o destrucción de datos del sistema, o que causa un ataque de denegación de servicio, (iv) sabotaje por parte de un miembro del personal con una queja o rencor contra la empresa.

Una falla del sistema necesita un manejo cuidadoso, ya que puede ser el resultado de una violación de seguridad y esto puede involucrar a la policía. Informar y recuperarse de las fallas del sistema es importante para que su negocio vuelva a la normalidad lo antes posible. Estos fallos de sistema podrían afectar solo a una parte de la empresa o a su totalidad. La falla del sistema puede ser menor y la recuperación será rápida, o mayor y la recuperación llevará mucho más tiempo. La naturaleza y el impacto de los fallos determinarán qué acciones es necesario tomar para recuperarse.

Además, es necesario que la empresa considere si el fracaso tendrá un impacto externo en aquellas empresas que dependen de usted, por ejemplo, la cadena de suministro y los clientes. Es necesario incluir a las partes externas afectadas en el reporte del incidente.

El proceso de identificación de riesgos implica la recopilación de información, que puede implicar entrevistas con el personal, individualmente o en equipo. También puede incluir comentarios y opiniones de las partes interesadas, como proveedores, socios comerciales y clientes. Es importante tener en cuenta que las percepciones de riesgo varían de una persona a otra. Lo que una persona percibe como un riesgo, otra persona puede verlo de manera diferente. Es necesario que quienes tienen el control del proceso de identificación sean conscientes de las posibles variaciones de opinión tanto desde una perspectiva humana y como desde una perspectiva empresarial.

Hay muchas fuentes de información que hacen referencia a tipos de amenazas, vulnerabilidades y riesgos que su empresa puede querer consultar para determinar los riesgos a los que se enfrenta. Parte de esta información es genérica y, por lo tanto, será necesario adaptarla a su situación comercial particular. Además, es importante no olvidar sus propios registros de incidentes que puedan haber ocurrido en el pasado.

El resultado del proceso de identificación de riesgos debería ser una lista de riesgos, que luego se utilizará durante la etapa de análisis de riesgos (d).

Su empresa necesita determinar sus propietarios de los riesgos. El propietario del riesgo es responsable de los riesgos y tiene la autoridad de gestión para gestionar el control de los riesgos y para tomar decisiones sobre el control de los riesgos. Dependiendo del tamaño y la naturaleza de la empresa, su empresa puede tener un propietario del riesgo o varios



Estudio de caso

Una pequeña editorial especializada en publicaciones y revistas técnicas maneja un gran volumen de material protegido por derechos de autor de alto valor comercial. Está llevando a cabo una revisión de su seguridad de la información y ha identificado una serie de vulnerabilidades que abarcan el hardware, el software, las redes, las personas y la infraestructura, incluidas las siguientes:

- uso incorrecto del software y el hardware;
- capacitación insuficiente en concientización sobre la seguridad;
- procedimientos inadecuados de control de acceso;
- política sobre el uso del correo electrónico no desarrollada;
- procedimientos insuficientes para el manejo de material protegido por derechos de autor;
- protección física insuficiente del edificio y de las oficinas;
- falta de copias de seguridad o copias de seguridad incompletas;
- descarga y uso no controlado del software;
- mala gestión de contraseñas;
- almacenamiento sin protección;
- falta de mantenimiento del hardware;
- eliminación o reutilización de los medios de almacenamiento sin el debido borrado.

propietarios de los riesgos, cada uno responsable de diferentes tipos de activos o funciones comerciales, por ejemplo, procesos físicos, de información u operativos.

Ejemplos

Una pequeña empresa de cinco personas podría asignar a un miembro del personal como propietario del riesgo de toda la información y los procesos, y a otro miembro del personal como propietario de todos los demás riesgos que la empresa necesita controlar.

d) Analice los riesgos de seguridad de la información

Esta etapa del proceso se ocupa de determinar el nivel de riesgo en función de los impactos (o consecuencias) del riesgo y la probabilidad de que se presenten los riesgos. El impacto se refiere a la pérdida de confidencialidad, integridad y disponibilidad y a su relación con los procesos y objetivos comerciales habilitados mediante el uso de la información y los activos relacionados. Por ejemplo, el robo de datos es un problema de seguridad relacionado con la pérdida de confidencialidad, pero esto también tiene un impacto más amplio en el negocio y en sus objetivos.

La gravedad de este impacto puede afectar a parte o a la totalidad del negocio; puede representar una pérdida leve, una pérdida importante o una pérdida grave o crítica. Las pérdidas pueden ser financieras, como multas o sanciones o costos legales, pérdidas de operaciones y productividad, pérdidas de servicios, pérdidas de ventas o pedidos, o pérdidas de imagen o reputación, todas como resultado de una vulneración de la seguridad de la información de la empresa. Esta pérdida podría ser mínima, y tener un efecto leve o medio en el negocio, o podría tener efectos en la capacidad de la empresa para funcionar y operar normalmente y, en el peor de los casos, provocar un cierre de las actividades comerciales.

Como se menciona en los ítems a), b) y c), existen varios métodos que se pueden utilizar en el proceso de evaluación de riesgos. La NTC ISO/IEC 27001:2022 no prescribe ningún método en particular y deja la selección de un método apropiado a decisión de la empresa. Se puede seleccionar cualquier método siempre que cumpla con los requisitos de los ítems 1) a 3) del ítem d) del numeral 6.1.2 de la NTC ISO/IEC 27001:2022.

Al valorar la gravedad de los posibles impactos, puede utilizar un enfoque cualitativo o cuantitativo. Un enfoque cualitativo implica asignar niveles de gravedad (por ejemplo, bajo, medio, alto) a cada impacto.

Un enfoque cuantitativo implica asignar un valor numérico o medible a cada impacto, por ejemplo, una cantidad financiera, un valor de productividad (p. ej. a pérdida porcentual) o una pérdida de servicio en horas de indisponibilidad.

La evaluación de la probabilidad de que el riesgo se presente se puede basar en datos históricos de pasados problemas internos de seguridad, pasados informes de incidentes, datos y estadísticas de la industria, y en otras fuentes de datos que han registrado la probabilidad de que se presente el riesgo.

Para determinar el nivel de riesgo, es necesario combinar tanto el valor del impacto como el valor de la probabilidad. El siguiente ejemplo de estudio de caso ilustra una forma de lograr esto.



Estudio de caso

Un negocio pequeño utiliza la siguiente tabla para calcular el nivel de riesgo:

		Probabilidad				
		MB	B	M	A	MA
Impacto	MA	5	6	7	8	9
	A	4	5	6	7	8
	M	3	4	5	6	7
	B	2	3	4	5	6
	MB	1	2	3	4	5

Mapa 1 del nivel de riesgo

Leyenda: MB muy bajo, B bajo, M medio, A alto, MA muy alto

En esta tabla (Mapa 1 de nivel de riesgo), 9 representa un nivel de riesgo muy alto y 1 representa un nivel de riesgo muy bajo. A medida que el impacto aumenta de muy bajo a muy alto, y el valor de la probabilidad también aumenta, entonces el nivel de riesgo aumenta: cuanto más altos sean el impacto y la probabilidad, más alto es el riesgo; mientras que cuanto más bajo sean el impacto y la probabilidad, más bajo será el riesgo. Si su empresa utiliza este método, puede escoger un conjunto diferente de escalas diferentes para su análisis, por ejemplo, una escala de tres, cuatro o seis puntos, o más. Los ejemplos que aparecen aquí y en otras partes de este manual son ilustraciones genéricas para describir el proceso general de gestión del riesgo.

Otra parte importante del proceso de análisis es comprender los eventos, los incidentes y las causas que probablemente tengan un impacto en sus activos de información. Una falla accidental del sistema causará la pérdida de disponibilidad de la información; además, puede causar la eliminación o modificación de información.

Un ataque de piratería deliberado contra sus sistemas puede causar la eliminación intencional de información, el robo de información o la ejecución de un virus en el sistema, y provocar una serie de daños. Descargar un archivo a través de un sistema de correo electrónico puede causar daños si el archivo contiene material inseguro. La falta de copias de seguridad periódicas de la información puede causar una serie de problemas empresariales y de seguridad de la información. Estos son solo algunos de los muchos ejemplos de causa y efecto que pueden tener un impacto dañino en su empresa.

Al valorar el nivel de riesgo, es importante considerar qué tipo de controles de seguridad de la información existentes están disponibles.



Estudio de caso

Un pequeño estudio de diseño que presta servicios a compañías que desean un sitio web para su negocio se encuentra en la etapa de análisis de riesgos. Decide revisar sus controles existentes como parte del proceso de análisis para comprobar la pertinencia y la eficacia de estos controles. Durante el análisis, la empresa detecta lo siguiente:

- Un procedimiento existente sobre el uso de archivos adjuntos en los correos electrónicos está mal escrito y es necesario revisarlo. El usuario experimentado no utiliza el procedimiento, ya que sabe cómo manejar información confidencial; sin embargo, en el caso de un miembro del personal no capacitado existe el riesgo de que la información confidencial se envíe por correo electrónico.
- El procedimiento de control de acceso está desactualizado, ya que no abarca algunas de las tecnologías recientes que se han incorporado al negocio.
- Los procesos existentes para la eliminación o el almacenamiento de información han dado lugar a varios fallos de hardware. La empresa necesita revisar esta situación y luego implementar un sistema de almacenamiento más confiable y efectivo.

Su empresa debería adoptar el enfoque más adecuado para realizar este análisis, que sea compatible con los procesos y prácticas de gestión existentes. Hay varias formas que se podrían considerar, por ejemplo, reuniones grupales con la dirección y el personal, entrevistas o discusiones con miembros individuales del personal, responsables de ciertos aspectos de la seguridad, cuestionarios para el personal, revisión de informes de incidentes pasados y revisiones de seguridad, discusiones sobre la retroalimentación de los clientes y socios comerciales. El proceso de evaluación de riesgos es un esfuerzo de equipo, y la participación y el compromiso del mayor número posible de miembros del personal proporcionarían los mejores resultados, ya que se dispondría de una mayor variedad de comentarios de retroalimentación, puntos de vista y experiencias.

e) Evalúe los riesgos de seguridad de la información

Después de identificar los riesgos para la seguridad de la información por medio de los resultados del análisis de riesgos (numeral 6.1.2 ítem c) de la NTC ISO/IEC 27001:2022), de acuerdo con los criterios de riesgo (numeral 6.1.2, ítem a) de la NTC ISO/IEC 27001:2022), el siguiente paso es determinar la escala de estos riesgos identificados.

Un método para ilustrar el riesgo es en términos de la probabilidad de que una amenaza afecte su información y de su impacto en caso de que se presente. Esto se pueden representar en un diagrama, que a veces se denomina mapa de calor. Los mapas de calor de las Figuras 1 y 2 ilustran los niveles de riesgo agrupados en tres colores: gris oscuro, gris claro y blanco. El gris oscuro representa un nivel de riesgo alto, el gris claro un nivel de riesgo medio y el blanco un nivel de riesgo bajo.

		Probabilidad				
		MB	B	M	A	MA
Impacto	MA					
	A					
	M					
	B					
	MB					

Figura 1. Mapa de calor del riesgo 1

Leyenda: MB muy bajo, B bajo, M medio, A alto, MA muy alto

		Probabilidad				
		MB	B	M	A	MA
Impacto	MA					
	A					
	M					
	B					
	MB					

Figura 2. Mapa de calor del riesgo 2

Leyenda: MB muy bajo, B bajo, M medio, A alto, MA muy alto

El mapa de calor del riesgo 1 en la Figura 1 tiene un nivel de riesgo aceptable más bajo en comparación con el del mapa de calor del riesgo 2 en la Figura 2, de modo que una empresa podría optar por utilizar el mapa 1, mientras que otra podría optar por el mapa 2.

Los mapas de calor del riesgo son simplemente ejemplos que ilustran la teoría detrás de la evaluación de riesgos.

Otros mapas de calor pueden tener escalas más grandes o pequeñas para los impactos, por ejemplo, escalas de 4, 6, 7 u 8 puntos, o un mayor número de grises. Véase, por ejemplo, la Figura 3.

		Probabilidad						
		MB	B	B-M	M	M-A	A	MA
Impacto	MA							
	A							
	M-A							
	M							
	B-M							
	B							
	MB							

Figura 3. Mapa de calor del riesgo 3

Leyenda: MB muy bajo, B bajo, M medio, A alto, MA muy alto

Su empresa define su propio mapa de calor en función de su apetito de riesgo. También le corresponde a su empresa decidir si utiliza este método; podría elegir uno diferente.

En la etapa de evaluación de riesgos, es necesario que su empresa decida si los riesgos son aceptables, o si es necesario reducir los riesgos a un nivel aceptable mediante el tratamiento de los riesgos. Con el ejemplo de la Figura 1, su empresa decide que los riesgos de color gris oscuro no son aceptables; sin embargo, en el área de color gris claro, su empresa podría llevar a cabo un análisis de costo-beneficio sobre cualquier tratamiento de los riesgos propuesto y sobre las oportunidades comerciales, y luego compararlo con los impactos comerciales. Después de este análisis de las áreas de color gris claro, su empresa podría decidir dejar algunos riesgos en esta área y tomar medidas para monitorear de cerca la situación en una revisión y reevaluación tempranas, con el fin de comprobar que la situación no cambie y que el riesgo no se mueva hacia el área de color gris oscuro.

Por supuesto, después de este análisis de los riesgos de color gris claro, podría decidir que mover algunos riesgos hacia el área blanca mediante un tratamiento de los riesgos es un beneficio comercial. Un análisis de costo-beneficio es una técnica útil para determinar si los costos del tratamiento de los riesgos son proporcionales, al considerar los costos de los incidentes. Además, en sí mismo, el tratamiento del riesgo puede crear oportunidades, y los costos y beneficios de estas oportunidades se deberían incluir en el análisis de costo-beneficio.

La creación de un registro de riesgos es una buena práctica. Esta será una lista de todos los riesgos que haya identificado, como resultado de su evaluación de riesgos. Es una buena idea priorizar la lista de acuerdo con la gravedad del riesgo, de muy alta a baja. En la Figura 4 se muestra un ejemplo de priorización en términos de riesgos bajos, medios, altos y muy altos.

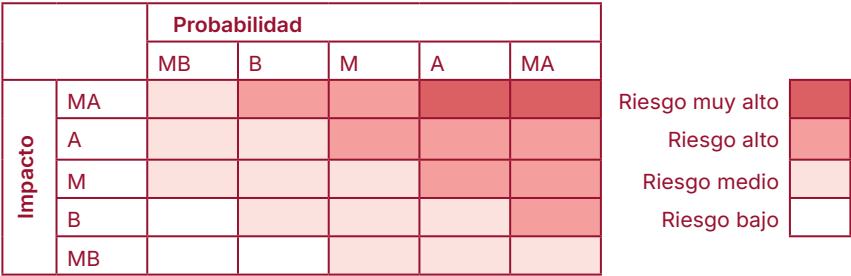


Figura 4. Mapa de calor del riesgo 1

Leyenda: MB muy bajo, B bajo, M medio, A alto, MA muy alto

La priorización del tratamiento del riesgo le ayuda a su empresa a asignar sus recursos de acuerdo con esta priorización. Por ejemplo, los riesgos que se consideran críticos podrían ser los que se asocian con impactos severos, que, a su vez, podrían tener un efecto crítico en los sistemas comerciales, procesos o servicios de su empresa. Por el contrario, los incidentes con riesgos bajos, y con probabilidades bajas de ocurrencia probablemente no se considerarían críticos; mientras que los riesgos de alto impacto, por lo general exigen una acción inmediata u oportuna para eliminar dichos riesgos o reducirlos a niveles aceptables.

El numeral 6.1.2 de la NTC ISO/IEC 27001:2022, exige que las organizaciones identifiquen los riesgos y los valoren, y que documenten tanto el proceso como los resultados de la evaluación de riesgos. Un registro de riesgos es una forma comprobada y eficaz de realizar estas tareas. Su empresa tiene la libertad de decidir cómo organizar su registro de riesgos. El siguiente es solo un ejemplo de un registro de riesgos:

	Descripción	Activos afectados	Comentarios
Riesgos muy altos			
[nombre del riesgo]			
[nombre del riesgo]			
Riesgos altos			
[nombre del riesgo]			
[nombre del riesgo]			
Riesgos medios			
[nombre del riesgo]			
[nombre del riesgo]			
Riesgos bajos			
[nombre del riesgo]			
[nombre del riesgo]			

Figura 5. Ejemplo de un registro de riesgos

El nombre del riesgo es una etiqueta que su empresa le asigna al riesgo para facilitar su referencia. La descripción podría incluir las amenazas, los incidentes, las vulnerabilidades y los impactos asociados con el riesgo. Los activos afectados se podrían clasificar por el tipo de información afectada, de activos físicos, de tecnología, de servicios o de procesos.

6.1.3 Tratamiento de los riesgos de seguridad de la información

En primer lugar, esta cláusula exige que la empresa seleccione las opciones de tratamiento relevantes para los riesgos que haya determinado para la seguridad de la información, y que luego determine todos los controles necesarios para la opción de tratamiento del riesgo seleccionada. Por último, es necesario que su empresa compruebe el conjunto de controles determinados, en relación con el conjunto de controles de referencia del Anexo A de la NTC ISO/IEC 27001:2022, con el fin de establecer si ha omitido algún control.

Orientaciones

a) Opciones de tratamiento de los riesgos

La intención de este numeral es definir el proceso para tratar los riesgos de la información, de modo que los riesgos se eliminen, o que se reduzcan a niveles prácticos para que los riesgos residuales sean aceptables. El primer paso en este proceso es determinar las opciones adecuadas de tratamiento de los riesgos, que su empresa podría utilizar para hacerle frente a los resultados de su evaluación del riesgo (numeral 6.1.2 de la NTC ISO/IEC 27001:2022, y sección 6.1.2 de este manual).

La selección de las opciones de tratamiento debería ser consistente con los criterios establecidos en la sección 6.1.2 a de este manual), y con los objetivos comerciales.

Las opciones de tratamiento del riesgo incluyen las siguientes:

- **Aceptar el riesgo de manera consciente y objetiva:** puede ser que su empresa no tenga la capacidad de identificar los controles de seguridad adecuados para algunos riesgos o que el costo de implementar controles supere la pérdida potencial de que el riesgo aparezca. En estos casos, es necesario tomar la decisión de aceptar o no el riesgo, y de vivir con las consecuencias si el riesgo aparece. Debería documentar estas decisiones para que la dirección sea consciente de su posición de riesgo y acepte el riesgo con plena consciencia.
- **Compartir o transferir el riesgo:** transferir o compartir el riesgo es una opción cuando pueda que reducir o controlar el riesgo a un nivel aceptable sea más difícil, o cuando transferirlo a un tercero pudiera ser más económico. Existen varios métodos para transferir el riesgo a otra organización, por ejemplo, a través de seguros o mediante subcontratación. Las compañías de seguros pueden proporcionar

cobertura de seguro una vez que se haya proporcionado toda la información de suscripción relevante (en este caso, el seguro consiste en una indemnización si la póliza cubre el riesgo). Al utilizar el seguro como un mecanismo de riesgo compartido, debería identificar cuánto se reduce el riesgo real, de modo que en la práctica siempre habrá algún riesgo residual del que usted es responsable. En general, el seguro no proporciona una mitigación inmediata en caso de un incidente o un ciberataque, por ejemplo, un pirata informático que altere sus sistemas.

- **Evitar el riesgo:** la evitación de riesgos describe cualquier acción que modifique las actividades comerciales de su empresa con el fin de evitar que se presente el riesgo. Por ejemplo:
 - interrumpir ciertas actividades planificadas, como dejar de utilizar internet para ciertas actividades comerciales;
 - mover activos de un área de riesgo, como dejar de almacenar archivos sensibles en una ubicación determinada porque no están suficientemente protegidos;
 - decidir no procesar información sensible, por ejemplo, con un tercero, si no se puede garantizar una protección suficiente.

La evitación de riesgos se debería equilibrar de acuerdo con las necesidades comerciales y financieras de su empresa. Por ejemplo, podría ser esencial utilizar internet por las demandas comerciales, a pesar de las preocupaciones sobre los piratas informáticos, o podría no ser factible trasladar ciertos activos de información y sus instalaciones de almacenamiento a un lugar más seguro. En tales casos, se debería considerar una de las otras opciones, la transferencia o la reducción del riesgo.

- **Reducir el riesgo:** esto implica implementar un conjunto de controles de seguridad de acuerdo con los resultados de su evaluación de riesgos. Se debería seleccionar un conjunto de controles para todos aquellos riesgos que haya decidido que se deberían reducir al nivel identificado como aceptable o al menos a un nivel adecuado según los criterios de aceptación de su empresa. Al identificar y seleccionar los controles, es importante considerar los requisitos de seguridad relacionados con los riesgos, por ejemplo, las amenazas y vulnerabilidades, los requisitos legales y reglamentarios, las obligaciones contractuales y todos los demás hallazgos de la evaluación de riesgos.

No existe un enfoque universal o normalizado para la selección de controles. Es probable que el proceso implique una serie de pasos de toma de decisiones y consultas y debates internos. El proceso debería arrojar un resultado que se adapte bien a su empresa y a sus objetivos, necesidades y requisitos comerciales en materia de protección de la información.



Estudio de caso

Una pequeña empresa manufacturera provee productos y piezas de repuesto a través de varias cadenas de suministro. Tiene una serie de diferentes activos de información que proteger, incluidos los relacionados con los clientes, los socios de la cadena de suministro, las transacciones de pagos, la información comercial interna y la información personal relacionada con el personal

Con base en su evaluación de riesgos, la empresa decide que se tiene que hacer frente a los riesgos más altos, como los riesgos para la información confidencial, mediante la implementación de controles para reducir el nivel de riesgo. En el caso de los activos de información que no se consideren sensibles, pero que sigan siendo esenciales para su negocio, el negocio subcontratará la gestión de los activos de información a través de un plan de riesgo compartido.

b) Determinar todos los controles que sean necesarios para implementar la o las opciones de tratamiento de riesgos de seguridad de la información elegidas

Lo ideal es que la selección de los controles para reducir los riesgos identificados tenga un enfoque de equipo, que involucre a personas de su empresa con diferentes áreas de conocimiento y experiencia, por ejemplo, alguien que se involucre en los aspectos de gestión, y alguien que se involucre en las operaciones cotidianas y, posiblemente, alguien con conocimientos técnicos.

El proceso de selección puede implicar varios pasos:

- Su equipo debería revisar cada riesgo individual identificado y seleccionar un control de seguridad, o una combinación de controles, para cada riesgo.

- La selección se debería basar en la reducción del riesgo a un nivel aceptable.
- Después de seleccionar un conjunto adecuado de controles, su equipo debería recalcular el nivel de riesgo en relación con la reducción alcanzada.
- Si el nivel de riesgo recalculado no está por debajo del nivel definido como aceptable, entonces su equipo debería considerar controles adicionales.
- Este enfoque iterativo debería continuar hasta que se alcance el nivel deseado de aceptación del riesgo, que frecuentemente se denomina riesgo residual. Es importante recordar que el nivel de riesgo nunca se puede reducir a cero; siempre habrá un nivel de riesgo residual.
- Este proceso se aplica a todos los riesgos identificados.

No existe un único conjunto de controles que pueda resolver todos sus problemas de riesgo. Por ejemplo, es poco probable que un control de seguridad de TI resuelva por sí solo sus problemas de riesgo. Lo que se necesita es una combinación de controles de los siguientes tipos:

- controles organizativos y de gestión;
- controles humanos;
- controles operativos;
- controles técnicos;
- controles físicos y ambientales;
- controles legales y regulatorios.

Esta combinación de controles es la esencia detrás del establecimiento y la implementación de un SGSI efectivo.



Estudio de caso

Un pequeño negocio de reservas de viajes les ofrece varios productos y servicios a los clientes. Cuenta con dos tiendas de viajes en diferentes ciudades y utiliza una serie de activos de información diferentes que necesita

proteger, en relación con los clientes, los proveedores de servicios de viaje (por ejemplo, aerolíneas, compañías ferroviarias, compañías de alquiler de carros, hoteles, cambio de divisas), las transacciones de pagos, la información comercial interna y la información personal relacionada con el personal.

Al seleccionar un conjunto de controles para gestionar sus riesgos de seguridad de la información, es necesario que la empresa considere los siguientes controles:

- controles técnicos para asegurar el acceso a las computadoras que procesan información comercial;
- controles de seguridad física para proteger frente al acceso no autorizado a los edificios fuera del horario de atención, a las oficinas y al almacenamiento físico;
- procedimientos para el personal, con instrucciones sobre cómo llevar a cabo sus trabajos y tareas de manera segura;
- políticas de gestión de seguridad;
- controles legales para garantizar que la información procesada vaya de acuerdo con la legislación, por ejemplo, para proteger la información personal, tanto información del personal como del cliente.

Esta es una muestra de los controles; es probable que haya otros que la empresa necesite considerar.

Los conjuntos de controles se pueden encontrar en las mejores prácticas y normas de la industria, las normas internacionales y otras fuentes. Los controles también se pueden diseñar según lo requiera su empresa, de acuerdo con lo que mejor se adapte a su negocio. Estos pueden ser un conjunto de controles de una norma modificada para su negocio.

Los controles de seguridad de la información se deberían implementar de manera que se complementen entre sí, ya que ningún control individual es la solución para todos los riesgos. Es necesario que los controles técnicos estén respaldados por controles de gestión y humanos, y viceversa. Es necesario que los controles operativos estén respaldados por controles técnicos y de humanos. Un enfoque exitoso y efectivo para reducir el riesgo es contar con una combinación adecuada de controles.



Estudio de caso

Una escuela primaria (para estudiantes entre 5 y 11 años) ya cuenta con una serie de controles de seguridad, entre ellos: (i) seguridad física en las puertas de la escuela, los edificios y las oficinas del personal, así como en los archivadores, y (ii) contraseñas para todas las computadoras escolares que utilizan el personal administrativo, los maestros y los estudiantes. Después de realizar una evaluación de riesgos, la escuela determina los siguientes controles adicionales (esta lista no es exhaustiva):

- procedimientos para el uso de internet, por ejemplo, para garantizar un uso seguro en línea y evitar la descarga de material no deseado o de un software malicioso (como un virus);
- procedimientos de copias de seguridad de los datos de toda la información que la escuela utiliza y procesa;
- procedimientos sobre el uso de correos electrónicos, que incluyan cómo protegerse contra el intercambio de información confidencial de la escuela;
- procedimientos sobre el uso seguro de los computadores portátiles de la escuela para los profesores que trabajan desde casa;
- procedimientos para la protección de datos personales;
- concientización del personal y de los profesores sobre la importancia de la seguridad de la información;
- uso de un software antivirus y actualizaciones periódicas del software.

c) Comparar la lista de controles necesarios con los del Anexo A de la NTC ISO/IEC 27001:2022 para evitar omisiones

El Anexo A de la NTC ISO/IEC 27001:2022 es una lista de referencias de controles de seguridad de la información. Se trata de controles de mejores prácticas que muchas empresas han desarrollado y adoptado en muchos sectores del mercado y en varios países. Por lo tanto, estos controles se han utilizado y ensayado en diferentes entornos comerciales. La lista no es exhaustiva, pero se puede aplicar a una amplia gama de situaciones de seguridad. Podría haber otras listas de controles o listas de verificación con un conjunto más extenso de elementos, pero el Anexo A de la NTC ISO/IEC 27001:2022 se deriva de la ISO/IEC 27002 y tiene un historial probado de aplicabilidad y de uso internacional como código de mejores prácticas.

La comparación de los controles necesarios, determinados en el proceso de evaluación de riesgos, con el contenido del Anexo A tiene por objeto garantizar que no se pasen por alto los controles necesarios de seguridad de la información; de modo que la función de esta comparación es un control en sí misma, en caso de que el proceso de evaluación de riesgos sea inmaduro o no haya identificado un riesgo o un control necesario para abordarlo.

Podría haber controles en el Anexo A de la NTC ISO/IEC 27001:2022 que no sean necesarios para una empresa, de acuerdo con sus actividades, tecnología, personas o tipo de negocio, y con la información que utiliza. La determinación de la necesidad de un control es responsabilidad de la propia empresa, por ejemplo, a partir de los resultados del proceso de evaluación del riesgo o según la necesidad de cumplir con obligaciones contractuales o legales.



Estudio de caso

Un pequeño bufete de abogados con 11 empleados, que les brinda ayuda y asesoramiento legal a pequeñas empresas, ya tiene un nivel básico de seguridad para proteger la información de los clientes. Después de realizar una evaluación de los riesgos, ha determinado que necesita controles adicionales, sobre todo para hacerle frente al aumento del uso de internet y de los dispositivos móviles. Después de comparar su lista de controles con los del Anexo A de la NTC ISO/IEC 27001:2022, el bufete de abogados descubrió que son necesarios otros controles,

- procedimientos para garantizar la seguridad y la protección del trabajo remoto: hay más trabajo fuera de la oficina, en casa o donde un cliente;
- mejora de la seguridad de la red para quienes trabajan de forma remota y desean conectarse a los sistemas de información de la oficina;
- mejora de la concienciación y de la formación en materia de seguridad de la información en lo que respecta su negocio.

d) Presentar una declaración de aplicabilidad

Una declaración de aplicabilidad es un documento que contiene la lista de controles que se han determinado a partir del proceso de (b) y los controles resultantes del proceso de comparación de (c). Además, debería contener una justificación de por qué estos se incluyen en la declaración de aplicabilidad, independientemente de que se implementen o no, y la

justificación de la exclusión de cualquiera de los controles del Anexo A. El documento ofrece un informe útil de los resultados de los procesos de evaluación de riesgos y de tratamiento del riesgo.

e) Formular un plan de tratamiento de los riesgos de seguridad de la información con la aprobación del propietario del riesgo

Es necesario que su empresa elabore un plan de tratamiento del riesgo, que debería detallar cómo se seleccionaron las opciones de tratamiento del riesgo y cómo se van a implementar. El plan debería incluir las razones por las que se han seleccionado esas opciones de tratamiento específicas y los beneficios que su empresa espera obtener. El plan también debería detallar las prioridades de las acciones que se van a llevar a cabo para implementar las opciones de tratamiento, la asignación de los recursos necesarios para la implementación y un cronograma para la entrega de la implementación.

f) Obtener la aprobación del plan de tratamiento de riesgos de seguridad de la información y la aceptación de los riesgos residuales de seguridad de la información, por parte del propietario del riesgo

Los propietarios de riesgos son las personas de la empresa responsables de los riesgos, la autoridad principal a la hora de tomar decisiones relativas a la gestión de los riesgos. Son responsables de la aprobación de los niveles residuales de riesgo y del plan de tratamiento de riesgos.

Numeral 6.2 Objetivos de seguridad de la información y planificación para alcanzarlos

Este numeral exige que la organización establezca un conjunto de objetivos de seguridad de la información, y especifica varios criterios que la organización debe considerar y aplicar a la hora de establecer cada objetivo.

Orientaciones

La intención de este numeral es establecer objetivos de seguridad de la información que sean relevantes para la empresa y estén alineados con los que se hayan identificado en los numerales 4 y 6.1.1 de la NTC ISO/IEC 27001:2022.

Esto incluye los siguientes aspectos:

- Garantizar que los objetivos sean consistentes con la política de seguridad de la información de su empresa. Esta política debería

indicar el compromiso y la orientación de la dirección de su empresa, y sus propósitos y objetivos en la protección de su negocio y sus activos frente a la pérdida de confidencialidad, integridad y disponibilidad. Este objetivo ayudará a la empresa a minimizar cualquier daño comercial, maximizar sus oportunidades comerciales e inversiones y garantizar la continuidad y disponibilidad de su negocio. Este tipo de política es de gestión de alto nivel y, como tal, solo puede tener de una a tres páginas.

- Que los objetivos sean medibles. Es importante tomar medidas para verificar y comprobar que se cumplen los objetivos y requisitos de seguridad de la información y que el SGSI sigue siendo eficaz. Puede que esto no sea factible en todos los casos.
- Garantizar que se tengan en cuenta los requisitos de seguridad de la información aplicables (numeral 4) y los resultados de la evaluación (numeral 6.1.2) y el tratamiento (numeral 6.1.3) de los riesgos.
- Monitorear, revisar y actualizar los objetivos cuando sea necesario.
- Comunicar los objetivos a todos los miembros de la empresa, especialmente cuando apliquen a funciones, responsabilidades y tareas individuales. Las comunicaciones son un aspecto importante de la gestión de la seguridad de la información, ya que los directores y el personal necesitan estar al tanto y mantenerse actualizados sobre los asuntos de seguridad de la información que puedan afectar sus funciones y al negocio.
- Documentar los objetivos a modo de informe, para que los directores y el personal lo utilicen como referencia, y garanticen su cumplimiento.

Su empresa necesita un plan que describa cómo va a alcanzar sus objetivos de seguridad de la información, entre los que se incluyan los siguientes:

- Definir **qué** hay que hacer: las actividades y acciones específicas que se van a implementar, los roles y las responsabilidades.
- Determinar **qué** recursos se requieren para implementar el plan, como el personal, el presupuesto y la tecnología.
- Identificar **quién** será el responsable de llevar a cabo cada una de las acciones del plan.
- Establecer un cronograma de **cuándo** se completará cada acción del plan.

-
- Definir **cómo** evaluar los resultados del plan y ajustarlo según sea necesario para garantizar que se alcancen los objetivos de seguridad de la información.

Numeral 6.3 Planificación de los cambios

Este numeral exige que la organización planifique cualquier cambio en el SGSI, cuando considere que necesita realizar dichos cambios.

Orientaciones

La intención de este numeral es planificar los cambios en el SGSI. Los cambios siempre son necesarios, ya sean cambios planificados que su empresa necesita realizar, por ejemplo, la adopción de una nueva tecnología o forma de hacer negocios, o cambios no planificados que no están bajo su control, por ejemplo, cambios en la cadena de suministro, una nueva legislación o un incidente de seguridad que supone cambios o mejoras en su sistema. Para estos dos tipos de cambio, es necesario que considere la seguridad de la información en la forma como su empresa se adaptará o responderá al cambio. Es necesario que considere su nivel actual de seguridad de la información y qué es necesario hacer para mantener o mejorar su eficacia.

Cuando haya identificado un cambio o cambios, es necesario que determine cómo estos encajan en su entorno comercial y en sus operaciones comerciales, asegurándose de que los cambios funcionan para su empresa y que no hay conflictos. Debería comprobar que los cambios no introducen riesgos o impactos adicionales, o, en caso contrario, definir cómo va a abordarlos. Es necesario que se asegure de que el personal haya recibido la suficiente concienciación y formación sobre estos cambios, incluida la formación en seguridad de la información. Cuando proceda, debería comunicar todos los cambios a las partes interesadas, por ejemplo, a los socios comerciales.



Estudio de caso

Una pequeña compañía de bodegas y almacenamiento propuso actualizar toda su TI e introducir más automatización en sus instalaciones de almacenamiento. Como estos cambios podían traer nuevos riesgos de seguridad de la información, la compañía necesitaba revalorar sus riesgos y decidir un conjunto adecuado de controles para gestionar aquellos riesgos que están por encima del nivel de aceptación. Además, la compañía necesitaba actualizar sus políticas y procedimientos de seguridad de la información para tener en cuenta estos cambios, y ofrecer formación y concienciación en el uso de la nueva TI. Los cambios pueden tener un impacto en las operaciones y prácticas comerciales existentes, lo que puede estar relacionado con la seguridad de la información. Estos cambios podrían tener un impacto en los requisitos legales y reglamentarios, por lo que es necesario valorar cualquier problema de incumplimiento. La compañía tendría que discutir cualquier implicación con el personal, por ejemplo, la introducción de la automatización, y ganarse su apoyo para estos cambios.

Una vez que su empresa haya aprobado una propuesta, es necesario implementarla de manera planificada y controlada para evitar interrupciones y fallas en el sistema de TI antiguo a nuevo. Esto debería implicar algún tipo de ensayo y validación de la nueva tecnología antes de usarla en las operaciones comerciales diarias. Además, es útil monitorear y revisar los cambios para comprobar que son eficaces y que no introducen nuevos riesgos o vulnerabilidades.

7. Apoyo

Este numeral consta de cinco numerales, y el numeral 7.5 consta de otros tres numerales:

7.1 Recursos

7.2 Competencia

7.3 Toma de conciencia

7.4 Comunicación

7.5 Información documentada

7.5.1 Generalidades

7.5.2 Creación y actualización

7.5.3 Control de la información documentada

Numeral 7.1 Recursos

La organización debe ofrecer los recursos necesarios para establecer, implementar, monitorear, revisar y mejorar continuamente el SGSI.

Orientaciones

La intención de este numeral es que la empresa determine y asigne los recursos que necesita para su SGSI. El término recursos se puede aplicar a las personas, la infraestructura, la tecnología, los presupuestos, los equipos físicos, los edificios y las oficinas. El numeral 7.1 de la NTC ISO/IEC 27001:2022 se refiere a la determinación y provisión de recursos específicamente para el establecimiento, la implementación, el mantenimiento y la mejora continua del SGSI.

Es importante que su empresa cuente con los tipos adecuados de recursos humanos para el trabajo que se debe realizar. Su empresa necesita personal con la competencia adecuada, por ejemplo, los servicios de atención al cliente necesitan personal que pueda tratar con los clientes, y el soporte técnico necesita personal que tenga los conocimientos técnicos y las habilidades para resolver problemas técnicos; y lo mismo pasa con la gestión de la seguridad de la información. La NTC ISO/IEC 27001:2022

no exige que las funciones y las responsabilidades de la gestión de la seguridad de la información sean trabajos o tareas a tiempo completo. Lo que se exige es que las funciones y responsabilidades estén claramente definidas y que se lleven a cabo cuando y como sea necesario. Puede ser necesario que los tipos de recursos exigidos para la gestión de la seguridad de la información estén dedicados a tareas específicas de gestión de la seguridad de la información, y algunos pueden estar relacionados con las tareas generales que realiza el personal. La empresa decide cuánto tiempo tiene el personal para llevar a cabo estas funciones y responsabilidades, y es probable que el personal necesite tiempo para llevar a cabo otras tareas y asignaciones de trabajo no relacionadas con la gestión de la seguridad de la información.



Estudio de caso

Un pequeño negocio de transporte ofrece servicios de transporte para escuelas, aeropuertos y hospitales. El negocio decide considerar los recursos necesarios en las siguientes áreas:

- políticas, procedimientos, revisiones, seguimiento y mejoras de la seguridad de la información;
- gestión de riesgos de la información;
- auditoría de seguridad de la información;
- seguridad de las TI;
- seguridad física.

Determinar qué recursos que se necesitarán incluye identificar el presupuesto necesario y si el personal interno tiene las competencias para cubrir la mayoría de estas áreas. De lo contrario, se requerirá apoyo externo.

Numeral 7.2 Competencia

La ISO define la competencia como la capacidad para aplicar conocimientos y habilidades con el fin lograr los resultados previstos. Este numeral especifica cuatro requisitos específicos para que una organización demuestre la competencia del personal involucrado en el establecimiento, implementación, operación y mantenimiento del SGSI.

Orientaciones

La intención de este numeral es determinar la competencia que se exige para los trabajos, tareas o actividades para el SGSI de su empresa. El objetivo es garantizar que los directivos y el personal que lleva a cabo esos trabajos o actividades tengan las competencias necesarias. La competencia se define como la capacidad para hacer algo con éxito o eficiencia. Esto exige ciertas habilidades, conocimientos, experiencia, y otros aspectos que podrían respaldarla. Por ejemplo, alguien que participe en la evaluación de riesgos debería tener conocimientos y experiencia en los principios del riesgo y en temas relacionados, en su relación con la gestión de seguridad de la información, en cómo interactuar con la dirección y con los propietarios de los riesgos en materia de la aceptación de riesgos y los criterios de evaluación de los riesgos, en cómo llevar a cabo la identificación, el análisis y la evaluación de los riesgos, en cómo involucrarse y comunicarse con otros miembros del personal para analizar los riesgos relacionados con el negocio de la empresa y en cómo documentar la evaluación de riesgos.

Una vez que su empresa haya determinado qué tipos de competencias se requieren, debería considerar al personal existente y sus habilidades, experiencia laboral, educación y formación en gestión de seguridad de la información. Cuando existe una brecha entre lo que se necesita y lo que está disponible, la empresa necesita determinar cómo va a cerrar esta brecha y ejecutar las acciones necesarias. Puede ser que se requiera alguna formación, más experiencia laboral o una ayuda externa a corto plazo.

Es importante tener en cuenta que tener educación y calificaciones no significa ser competente. Competencia es tener la capacidad de hacer algo de manera correcta, eficiente y eficaz. La experiencia laboral, el conocimiento práctico y la habilidad para realizar un trabajo son altamente relevantes y esenciales para tener competencia; al mismo tiempo, tener educación y formación es un apoyo importante para adquirir conocimientos.

Es importante comprobar si las acciones implementadas para adquirir las habilidades y la experiencia necesarias para apoyar el SGSI han sido eficaces. Si persisten brechas entre la competencia que tiene disponible y la competencia que necesita, se puede asegurar de que se resuelvan. Por ejemplo, si un miembro del personal ha realizado un curso de gestión de seguridad de la información y ahora tiene un nueva función, relevante

para el SGSI, es importante que este miembro del personal tenga la capacidad de adquirir experiencia laboral práctica en la aplicación de los conocimientos adquiridos durante el curso.

Los requisitos de competencia cambiarán con el tiempo, por lo que será necesario realizar revisiones periódicas de la competencia existente y de los nuevos requisitos, e implementar acciones para abordar las brechas que se identifiquen.



Estudio de caso

El propietario de un negocio unipersonal de consultoría de TI tiene un SGSI. Este director tiene una experiencia significativa ayudando a otras organizaciones a desarrollar, ejecutar y mejorar sus SGSI, y tiene experiencia en la gestión de los controles técnicos, físicos y organizacionales. El director también está suscrito a un servicio que ofrece actualizaciones de inteligencia periódicas sobre amenazas a la seguridad de la información, y dedica tiempo cada semana a mantener sus conocimientos actualizados. El director cuenta con una red profesional de expertos que pueden proporcionar más información o experiencia si es necesario.



Estudio de caso

Una panadería y pastelería familiar con cinco puntos de venta en diferentes ciudades ha adoptado un enfoque de SGSI en todo su negocio. Uno de los miembros de la familia tiene experiencia en tecnología, y esto los ha llevado a adoptar buenas prácticas de seguridad de TI para la empresa. Sin embargo, la empresa necesita que el personal adquiera competencia en los aspectos de gestión del uso en el SGSI. Algunos miembros del personal han recibido formación interna de concienciación para aumentar su competencia con respecto a la gestión de seguridad de la información, y a otros se les han asignado funciones y responsabilidades específicas.

Numeral 7.3 Toma de conciencia

Este numeral exige que todas las personas que trabajen bajo el control de la organización deben ser conscientes de la política de seguridad de la información, de su contribución al SGSI, y de las consecuencias de no cumplir con los requisitos del SGSI.

Orientaciones

La intención de este numeral es garantizar que el personal de su empresa sea consciente de la política de seguridad de la información, de los objetivos de seguridad de la información relevantes, de su contribución a la eficacia de su SGSI y de las implicaciones de no cumplir con los requisitos del SGSI.

Todo el personal que trabaja para la empresa debería tomar conciencia de los riesgos de seguridad de la información y tener una comprensión suficiente de estos riesgos y de sus consecuencias, con el fin de apoyar la política de seguridad de la información y ser capaz de llevar a cabo sus actividades laborales. Un aspecto importante de la concienciación es que todo el personal comprenda su propia contribución a la gestión de la seguridad de la información y que sea consciente de que esta contribución es esencial para la eficacia general de la gestión de seguridad de la información.

El personal debería participar en alguna capacitación general de concienciación sobre seguridad de la información como parte de su inducción al llegar a la empresa. También se puede llevar a cabo una capacitación de concienciación en el trabajo, que puede ser específica para la funciones laborales de la persona. Además, también se podría ofrecer una capacitación anual de concienciación para asegurarse de que el personal esté al día de cualquier novedad relacionada con las políticas y procedimientos de gestión de la seguridad de la información dentro de la empresa, y para recordarle los procedimientos de gestión de seguridad de la información existentes.

Además, todo el personal de su empresa se debería asegurar de que es consciente de las implicaciones de no cumplir los requisitos del SGSI. Por ejemplo, los problemas de no conformidad comienzan con personas que no siguen la política o los procedimientos de seguridad de la información, y esto puede traer consecuencias que resultan en daño o perjuicio para la empresa, lo que afecta a todo el personal. Como se menciona en el numeral 6, las consecuencias de una violación de la seguridad podrían implicar el robo de información, la pérdida de confidencialidad, integridad

o disponibilidad de la información, pérdidas para el negocio, acciones legales o daños a la imagen y la reputación. Dependiendo de la gravedad de la no conformidad, la empresa necesita implementar acciones que sean proporcionales al grado de no conformidad. Por ejemplo, puede ser una advertencia en los casos menos graves, o una acción disciplinaria o el despido en los casos graves más críticos. La empresa puede decidir qué acciones implementar de acuerdo con sus propias reglas internas en materia de disciplina.

Numeral 7.4 Comunicación

Este numeral exige que la organización determine las necesidades de comunicaciones internas y externas para el SGSI, específicamente respecto a qué comunica, cuándo, con quién y cómo.

Orientaciones

La intención de este numeral es establecer las comunicaciones internas y externas que su empresa necesita y que son relevantes para su SGSI.

Las comunicaciones son esenciales para el éxito general del SGSI. Si solo uno o dos miembros de su personal comprenden la importancia, relevancia y función del SGSI, entonces este no le sirve de nada a la empresa. En todos los niveles de la dirección y el personal de la empresa, es necesario que haya suficiente comunicación sobre el SGSI. Por ejemplo, es necesario comunicarle a todos la política de seguridad de la información, con el fin de que la entiendan y la apliquen. Es necesario comunicar los procedimientos relacionados con el acceso a las TI, las copias de seguridad, la protección de información sensible, la notificación de incidentes de seguridad, el acceso físico, el acceso de visitantes y otras actividades, para que todo el personal los conozca.

La empresa necesita decidir qué hay que comunicar y a quién, por ejemplo, qué hay que comunicarle al personal y qué hay que comunicarles a las partes externas. Es necesario comunicarle las políticas y los procedimientos de la empresa y sus actualizaciones a todo el personal.

Cuando la información sobre incidentes de seguridad que puedan afectar a la empresa sea de aplicación general es necesario comunicársela a todo el personal; y cuando los incidentes puedan impactar solo a un área de trabajo, solo es necesario comunicársela a una parte del personal. Es necesario comunicarles la notificación de incidentes a todas las personas relevantes. Cuando una violación grave de la seguridad tenga un carácter delictivo, se le debería comunicar a las autoridades policiales, así como

cuando pueda afectar a socios comerciales, proveedores o clientes. Del mismo modo, las partes externas podrían comunicarle a usted incidentes que estén afectando sus negocios, si existe la probabilidad de que estos tengan un impacto en su empresa.

La forma como se comunica es decisión de su empresa. Por ejemplo, podría decidir hacer reuniones con el personal, utilizar correos electrónicos, boletines informativos, avisos o informes internos u otros medios para comunicarse con el personal. Dependiendo de la urgencia de la comunicación, como en el caso de un incidente que exija una acción inmediata, la comunicación podría ser llamar a las personas relevantes.

Las comunicaciones se deberían documentar o grabar, sobre todo en el caso de un incidente de seguridad, ya que esto proporciona evidencia de lo que se comunicó, de cuándo se comunicó y de a quién se comunicó.

Ejemplos

Puede ser útil crear una tabla con cada una de las partes interesadas enumeradas en la primera columna y la información sobre qué comunicar, cuándo, con quién y cómo en las columnas siguientes, ya que esta información es específica para cada parte interesada. Independientemente de cómo decida documentar esta información, se debería poner a disposición de las personas de la empresa responsables de comunicarse con las diferentes partes interesadas, internas y externas

Numeral 7.5 Información documentada

Este numeral se divide en tres partes, que abarcan los requisitos generales, la creación y actualización de información documentada, y el control de la información documentada. Los numerales son los siguientes:

7.5.1 Generalidades

7.5.2 Creación y actualización

7.5.3 Control de la información documentada

7.5.1 Requisitos generales

Este numeral exige que la organización cuente con información documentada que sea apropiada para la escala de su SGSI, su complejidad, el tamaño de la organización, y las competencias de su personal.

Orientaciones

La intención de este numeral es garantizar que su empresa controle la información documentada necesaria para la conformidad con los requisitos de la NTC ISO/IEC 27001:2022, según sea necesario para la eficacia de su SGSI (véase el numeral 4.4.2 de la NTC ISO/IEC 27001:2022). Por ejemplo, las políticas y los procedimientos documentados, los resultados de la evaluación y del tratamiento de los riesgos, los informes de gestión, los informes de auditoría y los registros de desempeño.

Los siguientes son algunos ejemplos específicos que se exigen en la NTC ISO/IEC 27001:2022: los números entre paréntesis indican los numerales aplicables de la norma:

- política de seguridad de la información (5.2);
- información sobre el proceso de evaluación de riesgos para la seguridad de la información (6.1.2);
- declaración de aplicabilidad (6.1.3);
- registros de aprobación, por parte de los propietarios de los riesgos, del plan de tratamiento de riesgos de seguridad de la información, y aceptación de los riesgos residuales de seguridad de la información (6.1.3);
- evidencia documentada de la competencia de las personas que trabajan bajo el control de la organización (7.2);
- información para dar confianza de que se están llevando a cabo los procesos para cumplir con los requisitos de seguridad de la información (8.1);
- resultados de las valoraciones de riesgos de seguridad de la información (8.2);
- resultados del tratamiento de los riesgos de seguridad de la información (8.3);

-
- resultados del seguimiento y la medición (9.1);
 - programa(s) de auditoría y resultados de la auditoría (9.2);
 - resultados de las revisiones de la gestión (9.3);
 - no conformidades identificadas y cualquier acción posterior que se haya implementado (10.2);
 - registros de cualquier acción correctiva (10.2).

La NTC ISO/IEC 27001:2022 no es prescriptiva en cuanto al contenido o el alcance de la información documentada necesaria. Esto variará de una empresa a otra, en función de su tamaño y de la complejidad de su negocio, sus operaciones y sus procesos, así como de los requisitos legales y reglamentarios y del cliente. Por ejemplo, la información documentada en un pequeño negocio de transporte será más sencilla y menos extensa que la de una empresa mucho más grande. Esta última podría tener más requisitos externos y su información documental necesita cubrir operaciones comerciales más complejas.

Para asegurarse de que el SGSI refleja las necesidades de su empresa y la ayuda a ser lo más eficaz posible, será necesario contar con información documentada con el fin de garantizar la consistencia y la visibilidad de lo que se está haciendo para apoyar la seguridad de la información, de quién lo hace y de cómo lo hace.

7.5.2 Creación y actualización de información documentada

Este numeral exige que la organización tenga formatos y procesos de identificación, revisión y aprobación adecuados, a la hora de crear información documentada.

Orientaciones

La intención de este numeral es garantizar que, cuando cree y actualice información documentada para su SGSI, haya utilizado la identificación, el formato y los medios adecuados, y que esto se revise y apruebe.

La información documentada necesita tener algún tipo de identificación, por ejemplo, título, fecha, autor/propietario del documento o número de referencia (que se utiliza en alguna combinación que sea apropiada para su empresa). Esto permitirá que su empresa determine la información y su estado actual.

Además, su empresa necesita decidir un formato y un medio que sean adecuados para la información documentada; por ejemplo, copias impresas, formatos electrónicos o ambos. Si se utilizan versiones electrónicas, es necesario que su empresa se asegure de que todo el personal utiliza la misma versión de software para crear y actualizar la información documentada.

La empresa debe tener un proceso para la revisión y aprobación de la información documentada, y se debe otorgar a alguien de la empresa la autoridad para aprobar la información documentada.

7.5.3 Control de la información documentada

Este numeral es muy prescriptivo, pues contiene varios requisitos detallados para el control de la información documentada. Esto es para asegurar que el personal y las partes interesadas externas correspondientes reciban o tengan acceso a información documentada relevante que esté actualizada.

Orientaciones

La intención de este numeral es asegurar que la información documentada esté disponible en un formato y un medio apropiado siempre que se necesite. Además, es necesario protegerla adecuadamente para garantizar que se mantenga su confidencialidad, integridad y disponibilidad.

Es necesario que la información documentada esté a disposición de todos aquellos que necesiten acceder a ella, lo que puede incluir a partes interesadas externas. Es necesario que la información documentada esté en un formato que sea apropiado para su uso. La información documentada en formato electrónico es mucho más fácil de usar y compartir, lo que resulta útil para las partes externas y para los miembros de su personal que trabajen de forma remota. Es importante que existan controles adecuados, sobre todo para la distribución, la protección y el acceso a la información documentada. Es necesario que su empresa se asegure de que existen controles para su protección contra la pérdida de información, el uso inadecuado, los cambios no deseados y la pérdida de confidencialidad.

Con el fin de asegurarse de que su información documentada permanezca actualizada, completa y relevante a lo largo del tiempo, los documentos deben tener una fecha de revisión. De este modo, la organización debería validar que su información documentada se revise y apruebe dentro de

ese periodo de tiempo, por ejemplo, anualmente o cada dos años. Esto es importante porque la organización cambiará con el tiempo y la información en estos documentos puede quedar desactualizada, lo que puede conllevar que el personal no confíe en la información documentada o que no siga procedimientos o directrices desactualizados.

La información tiene diferentes niveles de sensibilidad o confidencialidad, y de criticidad. Por ejemplo, los registros financieros o la información personal sobre los empleados generalmente se considerarían más confidenciales o sensibles que la información anunciada públicamente sobre un producto o servicio. Hay muchas formas de clasificar la información, como la de uso público (no sensible), la de uso exclusivo interno, y la confidencial o restringida, a la que solo pueden acceder determinadas personas de la empresa, por ejemplo, la información financiera, la información de recursos humanos o la información que le da a su empresa una ventaja competitiva, como la información sobre el desarrollo de productos.

Su empresa debería determinar cómo y dónde se ponen a disposición los documentos con diferentes niveles de sensibilidad o confidencialidad. Por ejemplo, la información sobre sus productos o servicios que le gustaría que todo el mundo viera puede estar disponible en su sitio web o publicada en el muro de su tienda. Los documentos para uso interno pueden estar disponibles en el repositorio de documentos electrónicos de su organización o en un archivador. Los documentos restringidos son documentos que solo deberían estar disponibles para determinadas personas o equipos que tengan permitido verlos, por ejemplo, la información financiera solo se pone a disposición del equipo financiero o la información sobre incidentes de seguridad de la información solo se pone a disposición del equipo de operaciones de seguridad.

Es posible permitir que cierta información esté disponible para que algunas personas la lean, pero no realicen cambios. Se debería considerar cómo y cuándo puede ser necesario acceder a ciertos documentos. Por ejemplo, si el plan de continuidad de las actividades comerciales que explica qué hacer en caso de desastre solo está disponible electrónicamente en un sistema que puede colapsar a causa de un desastre, en cuyo caso no se podría ver ni utilizar, puede ser necesario almacenar una copia impresa o tener acceso a copias impresas de algunos documentos.

Los documentos se deberían controlar de manera que solo las personas autorizadas para verlos tengan acceso a ellos, y que las personas no puedan realizar cambios no autorizados ni compartirlos con alguien que no esté autorizado para verlos.

Puede ser necesario proteger ciertos tipos de información documentada mediante cifrados cuando se transfieren de una parte o ubicación a otra, por ejemplo, por correo electrónico, o cuando se almacenan.

Puede ser útil para su organización enumerar qué documentos o tipos de documentos se deberían distribuir y a quién, de modo que quede claro quién debería tener acceso a qué información. A continuación, su empresa puede organizar la distribución de documentos por tipo de documento o por quién los recibirá, así como por la fecha de distribución. Cuando sea posible, la información debería ser visible solo para aquellos que necesiten verla o usarla. Por ejemplo, su empresa puede permitir que solo determinadas personas vean o abran determinadas carpetas de archivos o documentos.

En lo que respecta al almacenamiento y la conservación de documentos, hay varias consideraciones. Los documentos se pueden almacenar de forma segura en otra ubicación o en la nube, y transferir física o virtualmente a otra ubicación para garantizar su conservación. Algunas empresas digitalizan sus documentos impresos para que puedan ser más accesibles. Los documentos archivados deberían retener la información relevante sobre los controles de acceso, de modo que, incluso una vez se hayan archivado, siempre quede claro quién los puede ver.

Su empresa debería tener un proceso definido para gestionar los cambios en los documentos y el control de versiones. Este proceso se debería aplicar de manera consistente, de modo que haya claridad sobre qué constituye un cambio de versión completo (por ejemplo, de la versión 1 a la versión 2), en contraposición a un cambio de versión parcial (por ejemplo, de la versión 1.1 a la 1.2). Las aprobaciones de las nuevas versiones de los documentos también se deberían llevar a cabo de manera oportuna, con el fin de evitar que las nuevas versiones queden inservibles durante meses mientras se espera la aprobación de un alto ejecutivo. La organización debería considerar cómo y cuándo alertar al personal y a otras personas relevantes sobre las nuevas versiones de los documentos, por ejemplo, de la última versión de una política.

Diferentes tipos de información, por ejemplo, la información financiera o aquella que incluye datos de identificación personal sobre empleados o clientes, pueden tener diferentes períodos de retención requeridos. Estos

períodos de retención a menudo se exigen según los requisitos legales, reglamentarios o estatutarios y las obligaciones contractuales, por lo que es esencial comprender cuáles son estos períodos de retención y cumplirlos.

Su empresa debería determinar cuáles son los diferentes períodos de retención para los diferentes tipos de documentos, y documentarlos, de modo que haya claridad sobre el período de retención exigido para cada tipo de documento. A continuación, se deberían realizar revisiones periódicas para garantizar que su empresa retiene los documentos de acuerdo con los períodos de retención documentados. Su empresa también debería determinar la disposición final de los documentos al término de su período de retención, es decir, si se destruirán, archivarán, facilitarán a otra parte, entre otros.

Su empresa debería garantizar que los documentos permanezcan legibles durante todo su período de retención. Por ejemplo, garantizar que el software disponible pueda leer los documentos o, si está impreso, que la copia impresa esté completa y sea legible.

Puede ser útil crear una plantilla común para todos los documentos internos que garantice que las marcas de clasificación siempre estén incluidas y sean visibles. Por ejemplo, el pie de página del documento puede incluir algo que diga "Solo para uso interno" o "Comercial confidencial", según el tipo de documentos. Determinar la ubicación y el acceso a los documentos internos se puede definir fácilmente. También se pueden definir y gestionar los períodos de retención de los documentos internos. Los documentos de origen externo que son necesarios para la planificación y la operación del SGSI, por ejemplo, un informe de desempeño de un proveedor que enumere las posibles vulnerabilidades de seguridad de la información, también requieren un proceso consistente para garantizar que haya claridad sobre la clasificación, el acceso, el almacenamiento, la retención y otras consideraciones relativas a estos documentos.

Algunas organizaciones recopilan, registran y gestionan los documentos de origen externo, tales como los informes de los proveedores o las propuestas de los clientes, de la misma manera como gestionan los documentos internos. Por ejemplo, la organización puede añadir una carátula con marcas de clasificación relevantes para mostrar el nivel de sensibilidad, el período de retención exigido y otros datos relevantes, e incluirla en el mismo sistema de gestión de documentos que se usa para los documentos internos. Otras organizaciones utilizan un proceso independiente para almacenar y gestionar los documentos de origen externo, por ejemplo, las normas internacionales, que pueden tener

requisitos de derechos de autor o contener datos de clientes, que, a su vez, pueden tener consideraciones de confidencialidad, privacidad u otras consideraciones contractuales.

8. Operación

Este numeral consta de tres numerales:

8.1 Planificación y control de la operación

8.2 Evaluación de los riesgos para la seguridad de la información

8.3 Tratamiento de riesgos de seguridad de la información

Numeral 8.1 Planificación y control de la operación

Este numeral exige que la organización planifique, implemente y controle los procesos exigidos para cumplir con los objetivos del SGSI, y gestione los riesgos identificados en el numeral 6, Planificación, de la NTC ISO/IEC 27001.

Orientaciones

La intención de este numeral es asegurar que usted planee, implemente y controle los procesos necesarios para su SGSI. Los riesgos y oportunidades se determinan durante la etapa de planificación del numeral 6.

Su empresa necesita tener un plan de acción para la implementación y el control de los procesos de acuerdo con los criterios sobre los procesos necesarios para cumplir con los requisitos y las acciones determinados en el numeral 6. Según el tamaño y la complejidad de su empresa, usted debería determinar qué recursos se necesitan y si el conjunto actual de recursos es suficiente. Los controles necesarios deberían confirmar que se cumplen los criterios, garantizar que se cumplan los objetivos del SGSI y determinar dónde se necesitan mejoras.

El proceso de evaluación de riesgos descrito en el numeral 6 dará lugar a un conjunto de riesgos priorizados para la acción y documentados en un registro de riesgos, de acuerdo con su gravedad. El proceso de planificación, a su vez, determinará qué técnicas y herramientas de control se requieren para cada riesgo. Por lo tanto, su empresa necesitará un plan para aplicar cada una de las técnicas y herramientas de control aplicables de manera sistemática y controlada.

Además, su empresa necesita establecer las actividades necesarias para controlar los cambios en los procesos de seguridad de la información que se hayan planificado. Esto incluye tanto los cambios en los procesos como los cambios en los criterios y las reglas utilizados para evaluar los procesos, y debería estar alineado con las acciones destinadas a cumplir los requisitos descritos el numeral 6.3 de la NTC ISO/IEC 27001.

Revise los cambios no deseados y las consecuencias de dichos cambios en los procesos de seguridad de la información, y tome medidas para mitigar cualquier efecto adverso. Esto incluye identificar y mitigar cualquier riesgo potencial que pueda surgir como resultado de cambios involuntarios en el SGSI, su contexto, políticas, roles y responsabilidades y en la capacidad para alcanzar los objetivos establecidos.

Asegúrese de que se controlan los procesos, productos o servicios que se proporcionan externamente y que son relevantes para el SGSI. Esto incluye asegurar que estos procesos cumplen con las reglas establecidas para los procesos internos de la empresa.

Numeral 8.2 Evaluación de riesgos para la seguridad de la información

Este numeral exige que la organización realice valoraciones periódicas de los riesgos, ya sea a intervalos planificados o cuando haya cambios significativos que resulten en cambios del SGSI.

Orientaciones

Su empresa necesita realizar valoraciones de los riesgos de seguridad de la información a intervalos planificados, o en caso de que se propongan o se produzcan cambios significativos, teniendo en cuenta los criterios establecidos mediante la aplicación del numeral 6.1.2 de la NTC ISO/IEC 27001. Realizar valoraciones periódicas de los riesgos de seguridad de la información es una actividad importante y esencial para garantizar que su SGSI esté actualizado y sea eficaz.

Hay muchos tipos diferentes de cambio que necesitarán una revisión de los riesgos. Por ejemplo, cambios en las necesidades y los requisitos de las partes interesadas, como se discute y determina en el numeral 4. Su empresa puede introducir nuevas tecnologías, o cambiar la forma como hace negocios, por ejemplo, mediante el uso de más transacciones y procesamientos en línea. Podría cambiar de proveedor de servicios o utilizar nuevos servicios, y el nivel de las amenazas para la seguridad podría cambiar. Todo esto puede traer nuevos riesgos y consecuencias

para su negocio. Por lo tanto, es necesario revalorar sus riesgos, con el fin de asegurarse de que su SGSI sigue siendo capaz de controlar los riesgos a los que se enfrenta.

La frecuencia de estas valoraciones dependerá del tamaño y la complejidad de su empresa, del tipo de información que se protege, del nivel de riesgo asociado con la información y de la tecnología utilizada para almacenarla, transmitirla y procesarla. No hay un período definido para saber cada cuánto hacer una evaluación de riesgos; su empresa decide la frecuencia. Esta necesita determinar, por ejemplo, si es necesaria una evaluación anual de riesgos o si el período debería ser más corto o largo.

Fuera de este período definido, siempre habrá casos que pueden exigir una evaluación de riesgos, cuando se hayan realizado cambios significativos o cuando haya ocurrido un incidente grave de seguridad.

Como se discutió en la sección de este manual sobre el numeral 6, es necesario que usted identifique y priorice los riesgos de la seguridad de la información, teniendo en cuenta su probabilidad e impacto. En esta evaluación, incluya los controles y acciones actuales destinados a mitigar estos riesgos, y evalúe su eficacia.

Documente los resultados de las valoraciones de los riesgos de seguridad de la información. Esta documentación debería incluir los riesgos identificados, la probabilidad y el impacto de estos riesgos, los controles que estén activos y cualquier control adicional diseñado para abordar estos riesgos.

Revise y actualice los resultados de las valoraciones de los riesgos de seguridad de la información con regularidad para garantizar que se gestionen de manera eficaz. Esto puede incluir la actualización del plan de tratamiento de los riesgos y la implementación de controles adicionales según sea necesario.

Cuando una empresa realiza valoraciones periódicas de los riesgos de seguridad de la información, puede garantizar que está gestionando eficazmente los riesgos de seguridad de la información y que está protegiendo sus activos de información. Esta información documentada sobre los resultados de las valoraciones también es un recurso valioso para comprender los riesgos de seguridad de la información y las acciones para mitigar estos riesgos.

Numeral 8.3 Tratamiento de riesgos de seguridad de la información

Este numeral exige que la organización implemente el plan de tratamiento de riesgos de seguridad de la información y que luego documente los resultados del tratamiento de riesgos de seguridad de la información.

Orientaciones

Se debería implementar el plan de tratamiento de los riesgos de seguridad de la información que se haya creado con la aplicación del ítem e) del numeral 6.1.3 de la NTC ISO/IEC 27001. La empresa debería asignar recursos suficientes para la implementación. El propósito del plan de tratamiento de los riesgos es abordar los riesgos identificados en el proceso de evaluación de riesgos; en la mayoría de los casos, esto significaría reducir el riesgo mediante controles que modifiquen la probabilidad de un evento o que reduzcan el impacto en los activos. Es necesario que los responsables de la toma de decisiones y los propietarios de los riesgos relevantes aprueben su plan de tratamiento de los riesgos, con el fin de garantizar que este se alinee con los objetivos comerciales de la empresa y con el proceso de gestión de riesgos establecido.

El plan de tratamiento debería incluir los riesgos y su impacto y probabilidad, el nivel del riesgo, las opciones de tratamiento para cada riesgo inaceptable, los controles necesarios, las responsabilidades para implementar controles específicos y las actividades para las personas o equipos apropiados.

Debería haber un cronograma para la implementación del plan, que considere la disponibilidad de recursos y las actividades que dependen de otros involucrados en la implementación.

Dé seguimiento y monitoree la implementación del plan, considerando si se cumple con el cronograma, si los recursos son suficientes y si el personal tiene las competencias suficientes para llevar a cabo las actividades e implementar los controles.

Su empresa debería retener la información documentada de los resultados de la implementación del tratamiento de los riesgos de seguridad de la información, incluidos los cambios realizados en el plan de tratamiento de los riesgos, el estado de la implementación y los riesgos residuales que permanezcan. Esto también debería incluir evidencia de la implementación

de controles y de cualquier riesgo residual. Esta documentación debería estar disponible para que los responsables de la toma de decisiones y los auditores relevantes la revisen.

Revise los resultados del tratamiento de los riesgos de seguridad de la información y actualice el plan de tratamiento de los riesgos según sea necesario para reflejar los cambios en el perfil de riesgo de la empresa o en los objetivos comerciales.

9. Evaluación del desempeño

Este numeral describe los requisitos para evaluar la eficacia del SGSI y consta de tres numerales:

9.1 Seguimiento, medición, análisis y evaluación

9.2 Auditoría interna

9.3 Revisión por la dirección

Los numerales 9.2 y 9.3 constan de numerales adicionales.

Numeral 9.1 Seguimiento, medición, análisis y evaluación

Este numeral exige que la organización determine a qué darle seguimiento, cuándo, cómo y dónde, e incluye las disposiciones para el análisis y la revisión de los resultados del seguimiento.

Orientaciones

La intención de esta numeral es que su empresa determine qué procesos de medición y seguimientos se requieren, cuándo realizar estos procesos, quién es responsable de ellos y cómo llevar a cabo el análisis y la evaluación de los resultados de estas actividades.

El numeral 9.1 de la NTC ISO/IEC 27001 es muy prescriptivo en tanto establece, en cinco partes, qué es exactamente lo que una empresa necesita hacer.

Numeral 9.1, ítem a). A qué es necesario darle seguimiento y cuándo: primero, la alta dirección debería explicar cuáles serían las pruebas convincentes de que el sistema de gestión de seguridad de la información está cumpliendo sus objetivos (numeral 5.2, ítem b)). Por ejemplo,

el incumplimiento de algún objetivo, como que no haya divulgación inapropiada de información personal, podría resultar en un incidente, como la pérdida de un computador portátil. Una medición adecuada en este caso es el número de incidentes. El propietario de la empresa también podría querer información adicional, como si las valoraciones de riesgos y las reuniones relacionadas se están llevando a cabo según lo programado.

En algunos casos, las mediciones se realizan durante un período. La NTC ISO/IEC 27001 se refiere a esta serie de mediciones como seguimiento.

Numeral 9.1, ítem b). Métodos de seguimiento, medición, análisis y evaluación: las mediciones pueden ser valores numéricos simples, como el número de personas que asistieron a un evento o el número de incidentes. Pueden ser proporciones, como el número de personas que asistieron dividido por el número de invitados, o una fórmula más compleja. Independientemente de la metodología, esto se debería definir para todas las medidas antes de que se realicen las mediciones correspondientes.

Se debería tener cuidado al realizar mediciones cuantitativas para evitar errores de medición. Se podría, por ejemplo, tomar el promedio de varias mediciones. También se debería tener cuidado al realizar mediciones cualitativas para evitar la subjetividad. Estos errores se pueden reducir al dar instrucciones para la asignación de valores. Por ejemplo, malo significa una puntuación inferior al 10 %.

Numeral 9.1, ítem c). Cuándo realizar el seguimiento y la medición: los tiempos y frecuencias en los que se realizan las mediciones pueden ser diferentes para diferentes mediciones. Por ejemplo, las mediciones de una actividad se podrían realizar una vez al mes, mientras que para otra se podrían realizar anualmente.

Numeral 9.1, ítem d). Quién realiza el seguimiento y la medición: este proceso se le debería asignar a los individuos que la gerencia decida.

Numeral 9.1, ítem e). Cuándo analizar y evaluar los resultados del seguimiento y la medición: el cronograma para el análisis y la evaluación se debería determinar según la criticidad del proceso que se está midiendo y monitoreando. Por ejemplo, ¿se trata de datos que servirán de base para una acción inmediata? No siempre es necesario analizar y evaluar los resultados tan pronto como se realizan las mediciones. En algunos casos, es preferible hacer una serie de mediciones y luego analizar los resultados.

Numeral 9.1, ítem f). Quién analiza y evalúa los resultados del seguimiento y la medición: se pueden exigir diferentes conjuntos de habilidades para la medición, el análisis y la evaluación. Esas diferencias se deberían tener en cuenta a la hora de asignar la responsabilidad del análisis y la evaluación.

Si bien es útil que el negocio escriba los planes para el seguimiento y las mediciones, las medidas, las fórmulas, los tiempos, quién hace qué y cuándo, la norma hace énfasis en los resultados. Son estos los que le informarán al negocio si el SGSI está cumpliendo sus objetivos.

Numeral 9.2 Auditoría interna

Este numeral consta de dos numerales adicionales:

9.2.1 Generalidades

9.2.2 Programa de auditoría interna

Numeral 9.2.1 Generalidades

Este numeral especifica que la organización tiene que realizar auditorías internas periódicamente para ofrecer información sobre si el SGSI es eficaz, se mantiene y cumple con los requisitos de la NTC ISO/IEC 27001.

Orientaciones

La intención de este numeral es que su empresa obtenga información a través de la realización de auditorías internas sobre el desempeño y la eficacia de su SGSI. Una auditoría interna debería ser una visión imparcial de si su SGSI se ha implementado y mantenido de manera efectiva. Esta auditoría se utiliza para determinar si su SGSI cumple con los requisitos de la NTC ISO/IEC 27001, así como con los requisitos de la empresa.



Estudio de caso

Un negocio de floristería en línea realiza auditorías internas anualmente. Sin embargo, recientemente ha experimentado varios incidentes de seguridad que han interrumpido el negocio, y que han conllevado un nivel de impacto medio. Entonces, la empresa decide llevar a cabo una auditoría interna para determinar si el SGSI sigue siendo eficaz y si opera como se espera. El objetivo de la dirección de la empresa es determinar la causa de las interrupciones, lo que les permite a ella y a los propietarios de los riesgos realizar las mejoras adecuadas.



Estudio de caso

El personal de recepción en una clínica tiene contacto diario con los pacientes, y aprovecha la oportunidad para obtener retroalimentación sobre si los pacientes están satisfechos con el servicio que reciben. Después de recopilar los comentarios de retroalimentación, el personal toma nota de las sugerencias y las comparte en las reuniones del personal.

Numeral 9.2.2 Programa de auditoría interna

Este numeral especifica los requisitos para planificar, establecer, aplicar y mantener un programa de auditoría interna.

Orientaciones

Su empresa necesita establecer, implementar y mantener un programa de auditoría. El programa debería establecer una serie de auditorías para un período de tiempo específico. Esto debería incluir la frecuencia con la que se debería llevar a cabo una auditoría (por ejemplo, mensual, trimestral, anual). El programa de auditoría debería definir los métodos que se utilizarán, que podrían incluir la observación del SGSI en operación, entrevistas con el personal relevante, un muestreo de los procesos en curso y el examen de la información documentada.

Al asignar personal para llevar a cabo las auditorías, su empresa necesita garantizar la objetividad e imparcialidad durante el proceso de auditoría. En general, un miembro del personal no debería auditar su propio trabajo.

Su empresa debería determinar el alcance de cada auditoría y los criterios de auditoría que se utilizarán. El alcance podría especificar áreas del negocio, procesos o actividades. Los criterios podrían incluir normas específicas que se van a utilizar, requisitos específicos que se van a verificar, o cuándo son necesarias las medidas correctivas y el plazo para realizar correcciones y mejoras. Una auditoría interna es una buena oportunidad para observar las debilidades y las áreas de mejora.

La auditoría debería dar lugar a un informe de auditoría en el que se detallen los hallazgos de la auditoría, las pruebas de no conformidad, las áreas de corrección y mejora. Este informe es necesario como un insumo para la revisión por parte de la dirección, que se describe en la siguiente sección.

Numeral 9.3. Revisión por parte de la dirección

Este numeral se divide en otros tres numerales:

9.3.1 Generalidades

9.3.2 Entradas de la revisión por la dirección

9.3.3 Resultados de la revisión por la dirección

Orientaciones

La intención de este numeral es garantizar que su empresa lleve a cabo revisiones por parte de la dirección.

El objetivo de la revisión es comprobar que su SGSI es:

- idóneo: ¿sigue cumpliendo su función?
- adecuado: ¿sigue siendo suficiente?
- eficaz: ¿sigue logrando los resultados esperados?

La dirección de la empresa debería revisar el SGSI a intervalos planificados para garantizar que funciona según lo previsto. Las revisiones pueden tener lugar a los intervalos que la dirección haya definido, a pesar de que normalmente las revisiones exhaustivas por parte de la dirección se realizan a intervalos anuales, aunque las organizaciones más complejas suelen realizar revisiones más pequeñas con mayor frecuencia, por ejemplo, una vez al mes o cada trimestre.

Esta revisión por parte de la dirección puede ser independiente o estar en combinación con otras reuniones de revisión por parte de la dirección. Por ejemplo, se puede llevar a cabo semanalmente, mensualmente, o coincidir con otras reuniones de la dirección, por ejemplo, las de planificación comercial, las de planificación estratégica o las operativas. Esto puede agregar valor y evitar múltiples reuniones redundantes.

Las reuniones de revisión tendrán una serie de entradas para considerar:

- Es necesario implementar las acciones decididas en reuniones previas. Por lo tanto, revisar el estado de las acciones de las reuniones de revisión anteriores es un primer paso importante, como en cualquier reunión formal con actas.
- Los problemas externos e internos, por ejemplo, los cambios en el mercado en el que opera el negocio y los eventos mundiales, que pueden afectar al SGSI. Dichos cambios pueden modificar la probabilidad de ataques cibernéticos; además, los cambios en la ley pueden afectar lo que las empresas tienen que hacer para preservar la seguridad y la privacidad de la información. Puede haber cambios internos, como la rotación de personal, la respuesta a nuevas oportunidades comerciales y la adopción de nuevas tecnologías, que afecten al SGSI.
- Los clientes también pueden tener nuevos requisitos que pueden afectar al SGSI.
- Los resultados de las mediciones y auditorías proporcionan información sobre el grado en el que el SGSI está cumpliendo sus objetivos. Las no conformidades, especialmente las no conformidades repetitivas, pueden resaltar áreas de debilidad en las que las mejoras pueden ser deseables.
- Los comentarios de los clientes y del personal también pueden identificar áreas del SGSI en las que se pueden realizar mejoras.
- Los riesgos cambian constantemente, por lo que las valoraciones de riesgos se tienen que realizar a intervalos planificados y cuando se propongan o se produzcan cambios significativos. Estos cambios pueden necesitar un cambio en los controles de seguridad de la información que se utilizan para mitigar el riesgo. Debido a que estos cambios afectan al SGSI, es importante incluirlos en la revisión por parte de la dirección.

-
- La dirección está comprometida con la mejora continua y la reunión de revisión es un buen momento para demostrar ese compromiso.

Los resultados más importantes de una revisión por parte de la dirección se refieren a las oportunidades de mejora y a los cambios que se van a hacer en el SGSI.

Las actas de la revisión por parte de la dirección sirven como un registro permanente de la reunión de revisión y de las decisiones tomadas.

10. Mejora

Hay dos numerales en este numeral final:

10.1 Mejora continua

10.2 No conformidad y acción correctiva

Numeral 10.1. Mejora continua

Una empresa debe implementar un proceso de mejora continua para garantizar la idoneidad, adecuación y eficacia de su SGSI.

Orientaciones

El objetivo de este numeral es garantizar que su empresa identifica las oportunidades de mejora de su SGSI. Las mejoras pueden le ayudar a su empresa a mantener su SGSI actualizado, lo que mejora el rendimiento y la eficacia, corrige o previene los efectos indeseables de los riesgos y sus consecuencias, y satisface las necesidades y los requisitos de las partes interesadas.

Las mejoras se podrían identificar a través de diferentes métodos, por ejemplo:

- resultados de valoraciones de riesgos (numerales 6 y 8 de la NTC ISO/IEC 27001), actividades de incidentes de seguridad e informes de amenazas emergentes que podrían tener un impacto potencial en la empresa;
- acciones resultantes de las actividades de seguimiento, auditoría interna y revisión (numeral 9 de la NTC ISO/IEC 27001);

- acciones para evitar la recurrencia de las no conformidades (numeral 10.2 de la NTC ISO/IEC 27001);
- retroalimentación de la dirección, el personal y de otras partes interesadas;
- cambios ocasionados por la introducción de nuevos comerciales y tecnologías.

Se deberían llevar a cabo mejoras para garantizar que su SGSI siga siendo eficaz, apropiado e idóneo para su empresa y para la protección de su información. Las mejoras serán necesarias durante un período de tiempo para garantizar que todos los cambios que afecten a su empresa se consideren desde una perspectiva del riesgo y el impacto.



Estudio de caso

Un pequeño estudio de arquitectura depende en gran medida del uso de la tecnología para producir diseños de edificios, oficinas y casas, y para comunicarse con sus clientes en lo referente a las especificaciones de diseño. Este revisa periódicamente sus necesidades y requisitos en materia de seguridad de la información, teniendo en cuenta los comentarios de retroalimentación y los informes sobre los riesgos actuales y emergentes, así como sus controles actuales de seguridad de la información y el desempeño y la eficacia de estos controles. Hace reuniones mensuales con el personal para discutir cualquier problema relacionado con la seguridad, con el fin de identificar cualquier oportunidad de mejora.

Numeral 10.2. No conformidad y acción correctiva

Este numeral exige que la empresa identifique las no conformidades, las responda, analice las causas de raíz y, a continuación, tome medidas para minimizar las posibilidades de que se repita la no conformidad, o, si es posible, para eliminarlas.

Orientaciones

La intención de este numeral es garantizar que su empresa gestione las no conformidades que haya identificado y que tome las acciones correctivas adecuadas para abordarlas.

Una no conformidad es el incumplimiento de los requisitos establecidos en la NTC ISO/IEC 27001; esto puede incluir problemas relacionados con estos requisitos, como el incumplimiento de los requisitos estatutarios o reglamentarios, la violación de las obligaciones contractuales, la violación de la política de seguridad de la información o los problemas que surjan de las partes interesadas externas. Su empresa debería implementar las acciones necesarias para investigar qué salió mal y las causas del problema, corregir los problemas y evitar que se repitan en el futuro. Su empresa debería tratar de eliminar las causas y los efectos del problema.

Las no conformidades se pueden identificar según diferentes fuentes, por ejemplo, las siguientes:

- revisiones por parte de la dirección (numeral 9.3 de la NTC ISO/IEC 27001) o auditorías internas (numeral 9.2 de la NTC ISO/IEC 27001);
- auditorías externas (de terceros), como auditorías de certificación;
- seguimiento y medición del desempeño (numeral 9.1 de la NTC ISO/IEC 27001);
- retroalimentación de los clientes, los socios comerciales y otras partes interesadas;
- incumplimiento de requisitos legales o estatutarios;
- problemas y observaciones que el personal y la dirección hayan identificado;
- problemas causados por proveedores externos.

Por ejemplo, (i) durante una auditoría interna (numeral 9.2.2 de la NTC ISO/IEC 27001) se notó que la dirección no le ha asignado a un miembro del personal la responsabilidad de informar sobre el desempeño del SGSI [numeral 5.3, ítem b), de la NTC ISO/IEC 27001]; (ii) durante una reunión de revisión por parte de la dirección (numeral 9.3 de la NTC ISO/IEC 27001) algunos de los controles especificados en el plan de tratamiento de los riesgos aún no se han implementado (numeral 8.3); (iii) un miembro del personal le informa a la dirección que el manejo de los datos personales no cumple plenamente la legislación vigente.

Su empresa debería revisar cada no conformidad para determinar sus causas y efectos, y si existe o es probable que aparezca en otros lugares de su empresa. Es necesario que identifique el alcance de las acciones necesarias en función del efecto de la no conformidad.

Puede que no siempre sea posible, técnicamente factible o rentable eliminar por completo la causa de cada no conformidad. En estos casos, necesita considerar acciones para minimizar los efectos de la no conformidad en su SGSI.

Su empresa necesita implementar las acciones adecuadas para controlar cualquier no conformidad relacionada con su SGSI, mientras lleva a cabo una investigación sobre la no conformidad y ejecuta su corrección. Por ejemplo, esto podría implicar ponerse en contacto con proveedores externos para informarles del problema y proporcionar información sobre los efectos en la gestión de seguridad de la información.

Su empresa debería revisar las acciones correctivas para garantizar que se hayan implementado de manera eficaz. Esto se podría respaldar mediante la observación del desempeño de su SGSI. La mera corrección de una no conformidad puede no resolver por completo el problema y este puede volver a ocurrir; por tanto, la causa de raíz se debería eliminar.

Después de revisar las acciones correctivas, debería considerar si los riesgos y las oportunidades no se abordaron, identificaron, analizaron o evaluaron completamente durante la evaluación de riesgos (numeral 6.1.2 de ISO/IEC 27001) o si el plan de tratamiento de riesgos no se implementó de manera eficaz. Al abordar las acciones correctivas, también debería decidir si es necesario hacer cambios en los procesos dentro de su SGSI, por ejemplo, ¿es necesario hacer cambios en su proceso de evaluación de riesgos?

Las no conformidades y las acciones correctivas se deberían documentar, con detalles sobre la gravedad de la no conformidad, la causa de raíz, la corrección planificada y la acción correctiva. Es necesario retener esta información documentada, ya que proporciona pruebas del análisis de la no conformidad, del análisis de las causas, de las acciones que se han implementado y de la eficacia de las acciones correctivas en el SGSI.

Ejemplos

No existe una lista normalizada de no conformidades, pero los siguientes son algunos ejemplos:

- definición inadecuada del alcance del SGSI (numeral 4.3) y, en particular, no abordar las interfaces y dependencias [numeral 4.3, ítem c)];
- la opción del plan de tratamiento de los riesgos para la reducción de los riesgos no logra determinar todos los controles necesarios para abordar los riesgos identificados durante la evaluación de riesgos [6.1.3, ítem c)];
- debido a un proceso inadecuado de evaluación de riesgos, la empresa no logra identificar una serie de riesgos importantes (6.1.2);
- no comparar adecuadamente los controles determinados en el numeral 6.1.3, ítem c), con los del Anexo A, lo que da lugar a que muchos de los controles del Anexo A se pasen por alto a la hora de realizar la comparación;
- la empresa no logra planificar cómo alcanzar sus objetivos de seguridad de la información (6.2) para decidir quién será el responsable de estos y cuándo se cumplirán [6.2, ítems j) y k)];
- falta de formación y concienciación (7.3);
- falta de recursos para apoyar el SGSI (7);
- la dirección no logra cumplir los resultados de la auditoría interna (9);
- la dirección no logra promover el objetivo en toda la empresa (5.1);
- la dirección no logra comunicarle la política de seguridad de la información a todos los miembros del personal (5.2);
- La empresa no logra implementar plenamente todos los controles identificados durante el proceso de tratamiento de los riesgos (6.1.3), lo que la deja vulnerable a amenazas y ataques, y a las consecuencias de estos.

NOTA: Los números entre paréntesis se refieren al número de numeral aplicable de la NTC ISO/IEC 27001.

Anexo A. Preguntas frecuentes

1. ¿Quién participó en el desarrollo de la norma ISO/IEC 27001?

El Comité Técnico Conjunto de la ISO y la IEC (JTC 1), Tecnología de la información, (TC), subcomité número 27 (ISO/IEC JTC 1/SC 27, Seguridad de la información, ciberseguridad y protección de la privacidad), es responsable del desarrollo y el mantenimiento de la norma ISO/IEC 27001. Esta norma se ha desarrollado sobre la base de las contribuciones de los expertos de los organismos nacionales de normalización, las contribuciones de las organizaciones de enlace y el proceso de consenso entre expertos.

2. ¿La NTC ISO/IEC 27001 aplica para una organización pequeña?

La NTC ISO/IEC 27001 es aplicable a cualquier tipo de organización, independientemente de su tamaño (pequeña, mediana o grande), su naturaleza (pública o privada) o su actividad principal (por ejemplo, servicios financieros, corretaje de seguros, servicios de transporte, pequeña producción de alimentos, pequeño negocio familiar, comercio minorista y fabricación). Véase la Introducción, respecto al tamaño de las pymes.

3. ¿Cuáles son los beneficios de implementar la NTC ISO/IEC 27001?

La organización puede establecer su SGSI mediante la implementación de la NTC ISO/IEC 27001, que preservará la confidencialidad, integridad y disponibilidad de su información. La implementación de la NTC ISO/IEC 27001 también les garantizará a todas las partes interesadas (por ejemplo, propietarios, accionistas, clientes, proveedores y organismos reguladores) que la seguridad de la información se toma en serio dentro de las organizaciones con las que trabajan. Esto ofrece los siguientes beneficios:

- reducción de los riesgos de ciberseguridad;
- protección de registros personales e información comercial sensible;

-
- ayuda en la demostración del cumplimiento de las leyes y reglamentos;
 - nuevas oportunidades de negocio;
 - mejora en los niveles de confianza de clientes y empleados.

4. ¿La organización puede excluir algún requisito de la NTC ISO/IEC 27001?

No. La exclusión de cualquiera de los requisitos especificados entre los numerales 4 a 10 no es aceptable cuando una organización afirma conformidad con la NTC ISO/IEC 27001. Es necesario implementar todos los requisitos de la NTC ISO/IEC 27001, sin excepciones. Tenga en cuenta que todos los requisitos de la NTC ISO/IEC 27001 están definidos en oraciones que utilizan la palabra “debe”.

5. ¿El organismo de normalización especifica algún método aceptable para el proceso de gestión de riesgos?

No, aunque el organismo de normalización declara que el proceso de evaluación y tratamiento de los riesgos de seguridad de la información descrito en el numeral 6 está alineado con los principios y directrices genéricas que se proporcionan en la NTC ISO 31000:2018, Gestión del riesgo. Directrices. Las empresas son libres de utilizar cualquier método que deseen para llevar a cabo una evaluación de riesgos, siempre y cuando el método cubra los requisitos del numeral 6.1.2, relativos a la identificación, el análisis y la evaluación de riesgos y a la repetición del proceso para obtener resultados válidos, consistentes y repetibles.

6. ¿Es necesario que la organización implemente todos los controles enumerados en el Anexo A de la NTC ISO/IEC 27001?

No. La organización debe determinar los controles en función de su resultado del tratamiento de los riesgos a partir de diversas fuentes. La NTC ISO/IEC 27001 exige que la organización compare los controles que haya determinado con los que se enumeran en el Anexo A para identificar si se ha omitido algún control necesario. La organización puede excluir uno o más de los controles enumerados en el Anexo A si existe una justificación suficiente. La organización tiene que implementar su plan de tratamiento de los riesgos (que contendrá los controles que haya determinado como necesarios) para gestionar los riesgos que ha identificado y valorado.

7. ¿Cuándo es aceptable excluir un control del Anexo A en la declaración de aplicabilidad?

Un control del Anexo A se puede excluir cuando la empresa no está expuesta al riesgo que ese control mitiga, o cuando ese riesgo es aceptable para la empresa. El Anexo A es un recordatorio útil a la hora de determinar los controles para evitar que se omita alguno de los controles necesarios.

8. ¿Existe un contenido mínimo o unos controles obligatorios a incluir en la declaración de aplicabilidad?

No hay un número mínimo de controles del Anexo A. La declaración de aplicabilidad debe contener los controles que la organización haya determinado, la justificación de su inclusión, su estado de implementación y la justificación de la exclusión de cualquiera de los controles enumerados en el Anexo A. La NTC ISO/IEC 27001 no define qué controles enumerados en el Anexo A se deben incluir en la declaración de aplicabilidad; de hecho, ninguno de los controles del Anexo A es un requisito.

9. ¿Existe una declaración de aplicabilidad normalizada para las pequeñas organizaciones?

No existe una declaración de aplicabilidad normalizada. La organización debería preparar cada declaración de aplicabilidad teniendo en cuenta su contexto, la evaluación de los riesgos y su tratamiento.

10. ¿Es necesario que el programa de auditoría interna cubra los controles adicionales que la organización haya determinado, aparte de los enumerados en el Anexo A?

El programa de auditoría interna tiene que abarcar todos los controles enumerados en la declaración de aplicabilidad, independientemente de la fuente de estos controles (por ejemplo, la fuente puede ser otra norma internacional, una norma regional, una norma nacional o una norma de la industria, o se puede tratar de un control que la organización haya diseñado).

11. ¿Es necesario que la organización realice una evaluación de riesgos cuando el alcance de su SGSI ha cambiado?

Sí. Se debe realizar una evaluación de riesgos siempre que se produzca o se proponga un cambio significativo. Un cambio en el alcance del SGSI es un ejemplo de un cambio significativo.

12. ¿Qué es la certificación del SGSI?

La certificación del SGSI es la garantía escrita (un certificado) que emite un organismo independiente cuando el SGSI en cuestión cumple con los requisitos específicos establecidos en la NTC ISO/IEC 27001.

13. ¿Es necesario que la organización solicite la certificación del SGSI?

La NTC ISO/IEC 27001 no exige que la organización solicite la certificación del SGSI. La empresa decide si necesita la certificación del SGSI.

14. ¿Es necesario que la organización busque el apoyo de una compañía de consultoría para establecer su SGSI?

Depende totalmente de la organización si emplea o no los servicios de una compañía de consultoría. No hay nada en la NTC ISO/IEC 27001 que obligue o exija el uso de consultores externos. Muchas organizaciones, incluidas las pequeñas empresas, implementan con éxito un SGSI sin necesidad de consultores externos.

15. ¿Cuál es la relación entre un SGSI y el cumplimiento normativo?

Un SGSI idóneo y eficaz le puede ayudar a la organización a cumplir con las leyes y los reglamentos relevantes. La organización debe identificar y abordar los requisitos de la legislación y la regulación como parte de la comprensión del contexto comercial del SGSI (véase la NTC ISO/IEC 27001, numeral 4.2).

16. ¿La organización puede integrar la NTC ISO/IEC 27001 con otras normas de sistemas de gestión (por ejemplo, la NTC ISO 9001 o la NTC ISO 22301) en un solo sistema de gestión?

Sí. La mayoría de las normas de sistemas de gestión elaboradas por la ISO han adoptado un enfoque armonizado. Esto ayuda a las organizaciones a integrar dos o más normas de sistemas de gestión. Con esta integración, una organización puede operar un único sistema de gestión que cumpla con los requisitos de dos o más normas de sistemas de gestión, por ejemplo, la NTC ISO 9001 (calidad) y la NTC ISO/IEC 27001 (seguridad de la información).

17. ¿La organización puede solicitarle a la ISO una certificación del SGSI?

No. La ISO desarrolla normas internacionales, como la norma ISO 9001 (calidad) y la norma ISO/IEC 27001 (gestión de seguridad de la información); la ISO no participa en la certificación y no emite certificados. Un organismo externo de certificación realiza la certificación, así que la ISO no puede certificar a una empresa u organización. Sin embargo, el ICONTEC sí podría emitir una certificación de este tipo, ya que es un organismo de certificación.

18. ¿Qué es la familia de normas ISO/IEC 27000?

La familia de normas ISO/IEC 27000 es una colección de normas internacionales, especificaciones técnicas e informes técnicos sobre los SGSI. La familia de normas ISO/IEC 27000 se ha ganado una reputación mundial como la base para el establecimiento de los SGSI. Algunas normas de esta familia proporcionan orientaciones para la implementación de la NTC ISO/IEC 27001; por ejemplo, la norma ISO/IEC 27005 ofrece orientaciones sobre la gestión de riesgos. Otras normas de la familia incluyen conjuntos de controles, por ejemplo, la norma ISO/IEC 27011 (Seguridad de las telecomunicaciones) e ISO/IEC 27017 (Seguridad de la nube), que la organización puede utilizar para el requisito de "determinación de controles" de la norma ISO/IEC 27001.

Para obtener más información sobre el subcomité técnico ISO/IEC JTC 1/SC 27, consulte <https://committee.iso.org/home/jtc1sc27>

19. ¿Dónde se pueden obtener copias de la familia de normas ISO/IEC 27000 e información sobre ellas?

Puede encontrar información sobre la familia de normas ISO/IEC 27000 en el sitio web de la ISO (www.iso.org), incluido el resumen, el estado y la fecha de publicación de las normas específicas. Las copias de las normas se pueden comprar en el sitio web de ISO o en su organismo nacional de normalización. La ISO ofrece la versión en inglés. Muchos organismos nacionales de normalización han traducido las normas internacionales como normas nacionales. A través de ellos, puede comprar las versiones en el idioma local

Anexo B. Certificación

Antecedentes

La certificación consiste en que un organismo independiente y competente (comúnmente denominado "organismo de certificación") garantice por escrito (mediante un certificado) que un sistema de gestión cumple con unos requisitos específicos. Por ejemplo, una garantía escrita (un certificado) de que un SGSI cumple con todos los requisitos de la NTC ISO/IEC 27001.

Una vez que haya implementado su SGSI, no es necesario que busque la certificación. Sin embargo, muchas pequeñas empresas optan someterse a una evaluación para la certificación, ya que es una buena manera de agregar credibilidad. Esto se debe a que la certificación le demuestra a sus clientes actuales y potenciales que usted cuenta con una garantía por escrito emitida por un tercero que indica que su SGSI cumple con los requisitos de la NTC ISO/IEC 27001.

Antes de que comience el proceso de certificación, es necesario que se asegure de que el SGSI de su empresa tenga todas sus partes en marcha y haya estado operativo durante al menos varios meses. Esto le permite ver el SGSI en acción y tener la oportunidad de mejorarlo. Cualquier mejora alcanzada en esta etapa puede hacer que el proceso de certificación sea más fluido, lo que a su vez puede ahorrarle tiempo y dinero.

Los organismos de certificación necesitan ver pruebas de que su SGSI se ha implementado y es eficaz, en otras palabras, estos organismos de evaluación necesitan ver lo que ha sucedido. Por lo general, esto implicará mostrarles la información documentada (registros), lo que les permitirá a los auditores observar sus procesos, entrevistar a su personal y realizar otras verificaciones, según sea necesario para confiar en su SGSI.

A continuación, se ofrece un breve resumen para aquellos que deseen seguir este camino.

Breve resumen

El requisito de demostrar que su SGSI cumple con la NTC ISO/IEC 27001.

La necesidad de demostrar que su SGSI cumple con la NTC ISO/IEC 27001 puede provenir de usted mismo o de otros organismos que tengan interés en su negocio. Algunas razones para hacer esto incluyen:

-
- identificar y corregir las no conformidades y buscar oportunidades para mejorar su SGSI a través de exámenes diferentes a las auditorías internas;
 - mejora del desempeño en el mercado, por ejemplo, es más probable que una empresa inmersa en un entorno altamente competitivo que cuente con un certificado del SGSI parezca confiable, en comparación con otra que no tenga un certificado, lo que ayuda a promover el desarrollo de su negocio;
 - requisitos contractuales, por ejemplo, sus clientes exigen la garantía de que su SGSI cumple con la NTC ISO/IEC 27001, y esta garantía la proporcionan ellos mismos o un organismo independiente;
 - requisitos legales o reglamentarios, por ejemplo, el regulador puede asesorar sobre cómo su SGSI le puede ayudar a su empresa a cumplir con las leyes o regulaciones.

Si existen requisitos reglamentarios y contractuales relacionados con la demostración del SGSI en su empresa, puede identificarlos en la NTC ISO/IEC 27001, numeral 4.2.

Enfoques para demostrar que su SGSI cumple con la NTC ISO/IEC 27001

El enfoque para demostrar que su SGSI cumple con la NTC ISO/IEC 27001 es la auditoría, que es un tipo de evaluación de la conformidad.

De acuerdo con la relación entre el organismo que realiza la auditoría y su empresa, existen tres tipos de evaluación: auditorías de primera parte (o autoevaluación), auditorías de segunda parte y auditorías de tercera parte.

Una auditoría de primera parte es una auditoría interna, tal como se define en la NTC ISO/IEC 27001, numeral 9.2; una auditoría de segunda parte es aquella que realizan sus clientes, ya sea directamente o a través de otro organismo que representa a sus clientes; y una auditoría de tercera parte es una auditoría realizada por un organismo de certificación. Este organismo es independiente de su empresa y no tiene ningún interés de usuario en su SGSI. Una auditoría de tercera parte también se denomina auditoría de certificación.

Su SGSI debería dar la confianza de que los riesgos de seguridad de la información de su empresa se gestionan adecuadamente. El nivel de confianza que ofrece su SGSI dependerá del resultado de la demostración

y de los enfoques de demostración que elija. Puede seleccionar un enfoque de demostración idóneo en función de las necesidades identificadas anteriormente.

En busca de la certificación del SGSI

Las razones clave para que una empresa busque la certificación del SGSI incluyen las siguientes:

- proporcionar garantías a sus clientes, socios comerciales y accionistas de que su SGSI es adecuado para su propósito y de que puede llevar a cabo su negocio de forma segura, por ejemplo, al proporcionar servicios de subcontratación;
- aumentar la confianza en su SGSI a través de las pruebas adicionales del organismo de certificación;
- sus clientes exigen una garantía independiente de conformidad con la NTC ISO/IEC 27001;
- cumplir con una ley o reglamento específico. por ejemplo, una legislación sobre protección de datos o privacidad;
- diferenciar la empresa de sus competidores en el mercado;
- facilitar el reconocimiento de sus productos o servicios en el mercado nacional o internacional.

En resumen, el valor de la certificación del SGSI proviene del grado de confianza del público en una auditoría competente e imparcial que realiza el organismo de certificación.

El proceso de certificación

La Figura B.1 representa un flujo de proceso típico del proceso de certificación. El organismo de certificación le otorgará a su empresa la certificación del SGSI después de aprobar la evaluación de certificación inicial; el certificado es válido por tres años. Después de que le hayan otorgado un certificado, comenzará el ciclo de certificación de tres años, durante el cual el organismo de certificación suele realizar la vigilancia de su SGSI en el primer y segundo año, y la recertificación en el tercer año, antes del vencimiento de la certificación. El siguiente ciclo de certificación de tres años comenzará después de la recertificación.

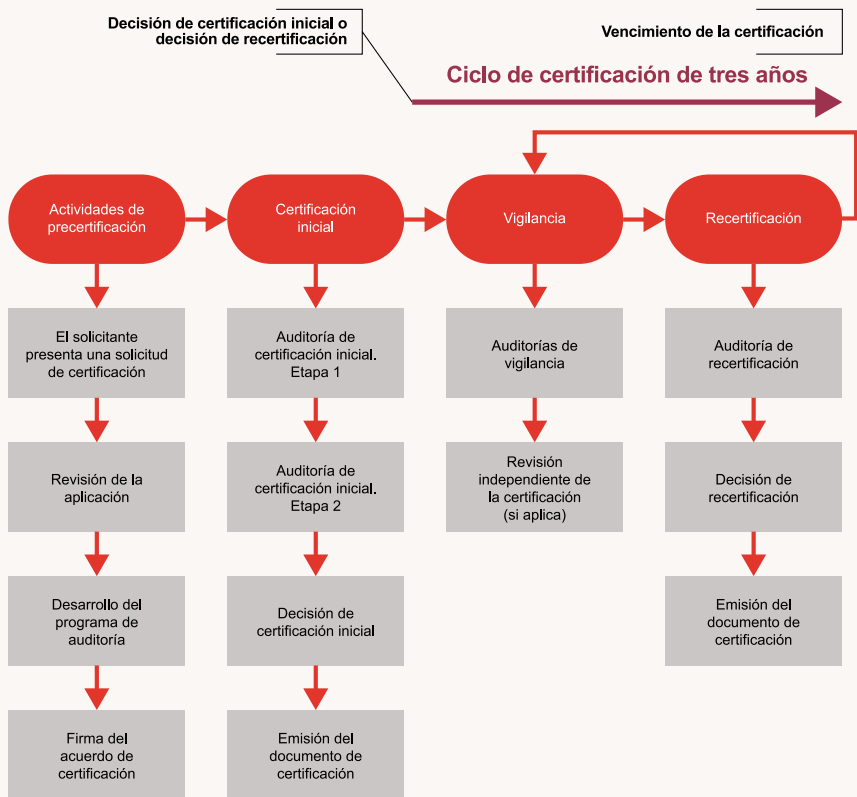


Figura B.1. Flujo de proceso típico del proceso de certificación

La auditoría de vigilancia se lleva a cabo al menos una vez al año. La fecha de la primera auditoría de vigilancia después de la certificación inicial no sobrepasa los 12 meses a partir de la fecha de decisión sobre la certificación.

A continuación, se ofrece información general sobre la auditoría y la toma de decisiones sobre la certificación, que son dos de las actividades clave en el proceso de certificación y pueden ocurrir muchas veces en un ciclo de certificación.

1) Auditoría

Por lo general, el organismo de certificación realizará una auditoría en las instalaciones de su empresa, aunque en algunos casos se permite una auditoría remota.

Quien realiza la auditoría es un equipo de auditoría competente, que incluye un líder de equipo y, en algunos casos, el apoyo de otros auditores y expertos técnicos. El equipo de auditoría acordará la fecha de la auditoría con la empresa. Antes de la auditoría, el equipo de auditoría le entrega el plan de auditoría a la empresa y, después de la auditoría, le entrega el informe de auditoría. El plan de auditoría puede incluir o referirse a lo siguiente:

- los objetivos de la auditoría, que están relacionados con el tipo de auditoría (por ejemplo, auditoría de certificación inicial, auditoría de vigilancia y auditoría de recertificación);
- la norma de certificación (basada en la NTC ISO/IEC 27001);
- el alcance de la auditoría (por ejemplo, el negocio o las unidades de su empresa);
- las fechas y los lugares en los que se llevarán a cabo las actividades de auditoría *in situ* y, cuando aplique, las actividades de auditoría remotas;
- las funciones y responsabilidades de los miembros del equipo de auditoría y de las personas que los acompañan (por ejemplo, observadores o intérpretes).

Los informes de auditoría que prepara el líder de auditoría pueden contener:

- un balance de la auditoría, incluido un resumen de la revisión de la documentación;
- un balance de la evaluación de riesgos de seguridad de la información de su empresa;
- la desviación del plan de auditoría (por ejemplo, mayor o menor duración de la auditoría);
- una referencia a la versión de la declaración de aplicabilidad;
- una conclusión sobre la idoneidad del alcance de la certificación;

-
- hallazgos de la auditoría, tanto positivas (por ejemplo, ventajas) como negativas (por ejemplo, no conformidades);
 - la recomendación del equipo de auditoría sobre si su SGSI se debería certificar o no.

2) Toma de decisiones sobre la certificación

El organismo de certificación revisará la información que proporciona el equipo de auditoría y tomará la decisión sobre la certificación (por ejemplo, otorgar, denegar, mantener, suspender, restaurar o retirar la certificación).

Es necesario que la o las personas involucradas en la toma de decisiones sobre la certificación posean la competencia exigida para evaluar los informes de auditoría y las recomendaciones del equipo de auditoría; además, deben ser diferentes de las del equipo de auditoría que realizó la auditoría.

La auditoría de certificación inicial

La auditoría de certificación inicial de un SGSI se lleva a cabo en dos etapas:

1) Etapa 1

El objetivo de la Etapa 1 es ofrecer un enfoque para la planificación de la Etapa 2 mediante la comprensión de su SGSI y, en particular, de su estado de preparación para la Etapa 2. La Etapa 1 incluye la revisión de la documentación de su SGSI y la visita a las instalaciones de su empresa.

En la Etapa 1, el organismo de certificación debería obtener la documentación sobre el diseño de su SGSI e informarle de cualquier otra información y registros que puedan ser necesarios para realizar un examen detallado durante la Etapa 2.

Al final de la Etapa 1, el organismo de certificación confirmará si la empresa está lista para la Etapa 2 o qué tiene que hacer para estarlo.

2) Etapa 2

La Etapa 2 tiene lugar en las instalaciones comerciales de su empresa. El propósito de esta etapa es comprobar si su SGSI cumple con cada uno de los requisitos definidos en la NTC ISO/IEC 27001, numerales 4 a 10. El equipo de auditoría del organismo de certificación se centrará en los siguientes aspectos de su empresa:

- evaluación de los riesgos de seguridad de la información y de sus resultados;

-
- determinación de los controles de seguridad de la información, incluida la declaración de aplicabilidad;
 - vínculos entre la política de seguridad de la información, los objetivos, los resultados de las valoraciones de riesgos de seguridad de la información y los controles determinados;
 - implementación de los controles de seguridad de la información que su empresa haya seleccionado;
 - evaluación del desempeño basada en los objetivos de seguridad de la información;
 - responsabilidad de la dirección en la política de seguridad de la información.

Mantenimiento de la certificación del SGSI

La validez de su certificado del SGSI se mantendrá a través de la vigilancia del organismo de certificación, por ejemplo, mediante una auditoría de vigilancia.

El objetivo de las auditorías de vigilancia es verificar que su SGSI certificado se sigue implementando y cumple con los requisitos de la NTC ISO/IEC 27001. Una auditoría de vigilancia puede abarcar los siguientes aspectos:

- gestión de riesgos de la información y mantenimiento de los controles;
- una revisión de cualquier cambio en su SGSI, incluidos los cambios en los controles de seguridad de la información;
- auditorías internas y revisiones de gestión;
- una revisión de las acciones implementadas para responder a las no conformidades identificadas durante la auditoría anterior;
- el proceso de las actividades planificadas destinadas a la mejora continua;
- tramitación de las reclamaciones;
- el uso de marcas y/o cualquier otra referencia para la certificación.

Preparación para solicitar la certificación del SGSI

Antes de presentar la solicitud de certificación al organismo de certificación, debería asegurarse de que su SGSI funciona sin problemas. Puede intentar evaluar su preparación para la certificación teniendo en cuenta lo siguiente:

1) Información documentada de su SGSI

La información documentada exigida en la NTC ISO/IEC 27001 se utiliza como evidencia de la implementación de su SGSI y se le puede proporcionar al organismo de certificación para su revisión. Usted debe asegurarse de que la documentación y los registros relacionados estén completos y sean suficientes antes de solicitar la certificación. En algunos casos, el organismo de certificación espera ver al menos tres meses de registros operativos de su SGSI al comenzar la Etapa 1.

2) Auditoría interna y revisión de la gestión

El organismo de certificación espera que su empresa haya completado al menos una auditoría interna y una revisión de gestión cuando presente la solicitud de certificación. Además, la auditoría interna debe determinar el alcance de la certificación que desea solicitar.

3) Alcance de la certificación

Usted le debe proporcionar el alcance deseado de la certificación al organismo de certificación cuando solicite la certificación. El alcance de la certificación puede ser igual o menor que el alcance de su SGSI. Usted puede determinar el alcance de la certificación solicitada en función de las necesidades de certificación que haya identificado. Además, el alcance de la certificación solicitada puede afectar el tiempo de auditoría y la tarifa de certificación.

Selección de un organismo de certificación

Seleccionar un organismo de certificación profesional y de buena reputación puede ser un proceso complejo. Hay varios factores para tener en cuenta:

1) Cobertura geográfica

Algunos organismos de certificación pueden cubrir un área pequeña, mientras que otros pueden operar en todo el mundo.

2) Experiencia industrial

Algunos organismos de certificación contarán con auditores con experiencia en muchos sectores industriales y comerciales (por ejemplo, finanzas, comunicaciones, aviación, comercio electrónico); otros se limitarán a unos pocos sectores.

3) Alcance comercial

El servicio de certificación de algunos organismos de certificación puede incluir muchas normas de sistemas de gestión, como la NTC ISO 9001 (gestión de la calidad), la NTC ISO 14001 (gestión del medio ambiente), la NTC ISO 22000 (gestión de la seguridad alimentaria), la NTC ISO/IEC 20000-1 (gestión de servicios), la NTC ISO/IEC 27001 (gestión de seguridad de la información) y la NTC ISO/IEC 27701 (gestión de la información sobre la privacidad); es posible que otros organismos de certificación solo cubran un número limitado de normas de sistemas de gestión.

4) Acreditación

La acreditación es una constatación independiente de la competencia del organismo de certificación, otorgada por un organismo de acreditación. Algunos organismos de certificación están acreditados según la NTC ISO/IEC 27006 1:2024, Seguridad de la información, ciberseguridad y protección de la intimidad. Requisitos para los organismos que realizan la auditoría y certificación de los sistemas de gestión de seguridad de la información. Parte 1: Generalidades, y según la norma NTC ISO/IEC 17021-1:2015, Evaluación de la conformidad. Requisitos para los organismos que realizan la auditoría y la certificación de sistemas de gestión. Parte 1: Requisitos.

La necesidad de acreditación depende de muchos factores. En algunas industrias, la acreditación es un requisito legal y se convierte en la normalidad esperada, lo que añade una capa adicional de confianza al mercado. La certificación acreditada es una forma, entre otras, de que una organización pueda demostrar su conformidad con la NTC ISO/IEC 27001.

Por lo tanto, se recomienda encarecidamente que la certificación seleccionada esté acreditada según la norma Seguridad de la información, ciberseguridad y protección de la intimidad. Requisitos para los organismos que realizan la auditoría y certificación de los sistemas de gestión de seguridad de la información. Parte 1: Generalidades, y la norma NTC ISO/IEC 17021-1:2015, Evaluación de la conformidad. Requisitos para los organismos que realizan la auditoría y la certificación de sistemas de gestión. Parte 1: Requisitos.

Además, algunos organismos de acreditación pueden ser firmantes del Acuerdo de Reconocimiento Multilateral (MLA, por su sigla en inglés) del Foro Internacional de Acreditación (IAF, por su sigla en inglés). Si su SGSI está certificado por un organismo de certificación acreditado por un organismo nacional de acreditación reconocido por la IAF, esto ayudará a que su certificado del SGSI sea ampliamente reconocido y aceptado en el mercado global.

5) Precios

Los precios de los organismos de certificación pueden variar enormemente. Algunos cobran gastos además de las tarifas normales, otros no. Los costos totales se deberían considerar durante al menos un período equivalente a los ciclos de certificación.

Al seleccionar una organización de certificación, usted puede verificar si el organismo de certificación se adhiere a las normas mencionadas anteriormente, y cuál es su estado de acreditación. Para localizar un organismo de certificación acreditado, comuníquese con el organismo nacional de acreditación de su país o explore el [CertSearch del Foro Internacional de Acreditación](#).

Anexo C. Sitios web y normas internacionales

C1. Sitios web de normalización

Organización Internacional de Normalización (ISO). [iso.org](https://www.iso.org)

Comisión Electrotécnica Internacional (IEC). [iec.ch](https://www.iec.ch)

Foro Internacional de Acreditación (IAF). www.iaf.nu

C.2 Sitios web de asociaciones de pymes para el comercio

Hay muchos sitios web en varios países dedicados a las pymes, por ejemplo:

Australia y Nueva Zelanda

Asociación de Pequeñas Empresas de Australia y Nueva Zelanda (Small Enterprise Association of Australia and New Zealand): www.seaanz.org

Canadá

Pymes. <https://ised-isde.canada.ca/site/sme-research-statistics/en>

Cámara de Comercio Canadiense (Canadian Chamber of Commerce): <https://chamber.ca/strategicissues/smes/>

Unión Europea

Pymes Digitales Europeas (European Digital SME): www.digitalsme.eu

Alemania

Pequeñas y medianas empresas (Mittelstand) de Alemania: <https://www.bmwk.de/Redaktion/EN/Dossier/sme-policy.html>

Japón

Agencia de Pequeñas y Medianas Empresas (Small and Medium Enterprise Agency): www.meti.go.jp

Organización para las Pequeñas y Medianas Empresas e Innovación Regional de Japón (Organization for Small and Medium Enterprises and Regional Innovation Japan): <https://www.jcci.or.jp/sme/>

Corea

Ministerio de Pymes y Emprendimientos (Ministry of SMEs and Startups): <https://www.mss.go.kr/site/eng/main.do>

Organización para la Cooperación y el Desarrollo Económico (Organisation for Economic Co-operation and Development, OECD): <https://www.oecd.org/cfe/>

Singapur

Asociación para Pequeñas y Medianas Empresas (Association of Small and Medium Enterprises, ASME): www.asme.org.sg

Suecia

Business-Sweden: <https://www.business-sweden.com/services/support-for-swedish-small-and-medium-sized-enterprises/>

Reino Unido

Centro de las Pequeñas y Medians Empresas (Small and Medium Business Hub): www.gov.uk/guidance/small-and-medium-business-hub

Federación de las Pequeñas Empresas (Federation of Small Businesses, FSB): www.fsb.org.uk

Estados Unidos de América

Administración de las Pequeñas Empresas de Estados Unidos (US Small Business Administration, SBA): www.sba.gov

Oficina de Centros de Desarrollo de la Pequeña Empresa (Office of Small Business Development Centers, SBDC): www.sba.gov/about-sba/sba-locations/headquarters-offices/office-small-business-development-centers

C2. C3. Normas internacionales

[1] ISO/IEC 27000:2018, *Information technology — Security techniques — Information security management systems — Overview and vocabulary*

[2] ISO/IEC 27001:2022, *Information security, cybersecurity and privacy protection — information security management system — Requirements*

-
- [3] ISO/IEC 27002:2022, *Information security, cybersecurity and privacy protection — Information security controls*
- [4] ISO/IEC 27003:2017, *Information technology — Security techniques Information security management systems — Guidance*
- [5] ISO/IEC 27004:2016, *Information technology — Security techniques Information security management — Monitoring, measurement, analysis and evaluation*
- [6] ISO/IEC 27005:2022, *Information security, cybersecurity and privacy protection — Guidance on managing information security risks*
- [7] ISO/IEC 27006-1:2024, *Information technology — Security techniques — Requirements for bodies providing audit and certification of information security management systems*
- [8] ISO/IEC 27007:2020, *Information security, cybersecurity and privacy protection — Guidelines for information security management systems auditing*
- [9] ISO/IEC 27011:2024, *Information technology — Security techniques — Code of practice for information security controls based on ISO/IEC 27002 for telecommunications organizations*
- [10] ISO/IEC 27017:2015, *Information technology — Security techniques — Code of practice for information security controls based on ISO/IEC 27002 for cloud services*
- [11] ISO/IEC 27019:2017, *Information technology — Security techniques — Information security controls for the energy utility industry*
- [12] ISO/IEC 17021-1:2015, *Conformity assessment — Requirements for bodies providing audit and certification of management systems — Part 1: Requirements*
- [13] ISO 31000:2018, *Risk management — Guidelines*
- [14] ISO 9001:2015, *Quality management systems — Requirements*

Acerca de la IEC

La IEC es una organización mundial sin ánimo de lucro que reúne a más de 170* países y coordina el trabajo de 20 000* expertos de todo el mundo.

Las normas internacionales de la IEC y el trabajo de evaluación de la conformidad sustentan el comercio internacional de productos eléctricos y electrónicos. Facilita el acceso a la electricidad y verifica la seguridad, el desempeño y la interoperabilidad de los dispositivos y sistemas eléctricos y electrónicos, incluidos, por ejemplo, los dispositivos de consumo, como los teléfonos móviles o los refrigeradores, los equipos médicos y de oficina, la tecnología de la información, la generación de electricidad y mucho más.

Para más información, visite www.iec.ch.

*para marzo del 2024



Facebook: facebook.com/InternationalElectrotechnicalCommission

Twitter: twitter.com/IECStandards.

Linkedin: ch.linkedin.com/company/iecstandards

Pinterest: pinterest.ch/iecstandards

YouTube: youtube.com/@IECstandards

Acerca de la ISO

La ISO (Organización Internacional de Normalización) es una organización internacional independiente y no gubernamental con una membresía de 170* organismos nacionales de normalización. A través de sus miembros, reúne a expertos para compartir conocimientos y desarrollar normas internacionales voluntarias, basadas en el consenso y relevantes para el mercado, que apoyen la innovación y proporcionen soluciones a los desafíos globales.

La ISO ha publicado más de 25 200* normas internacionales y documentos relacionados que cubren casi todas las industrias, desde la tecnología hasta la seguridad alimentaria, la agricultura y la atención médica.

Para más información, visite www.iso.org.

*para marzo del 2024



Sitio web de la ISO: www.iso.org

Sala de prensa de la ISO: www.iso.org/news

Videos ISO: www.iso.org/youtube

Síguenos en Twitter: www.iso.org/twitter

Síguenos en Facebook: www.iso.org/facebook

Acerca del ICONTEC

El ICONTEC (Instituto Colombiano de Normas Técnicas y Certificación) es una entidad de carácter privado, sin ánimo de lucro, que, según el Decreto 1595 de 2015, es el organismo nacional de normalización de la República de Colombia.

Como tal, es un miembro activo de los más importantes organismos internacionales y regionales de normalización, por lo cual participa en la definición y el desarrollo de normas internacionales y regionales.

Cuenta con alrededor de 300 comités técnicos que representan diversos sectores de la economía del país.

Para más información, visite www.icontec.org.

*para marzo del 2024



Sitio web del ICONTEC: www.icontec.org



ISBN: 978-628-7823-05-1



9 786287 182305

